INSA INSTITUT NATIONAL DES SCIENCES APPLIQUÉES LYON

Sécurité des Réseaux Cellulaires

Walid Bechkit, INSA-Lyon, INRIA-Agora

citi lab

Inria INVENTEURS DU MONDE NUMÉRIQUE

membre de UNIVERSITÉ DE LYON

Aperçu sur le contenu du cours

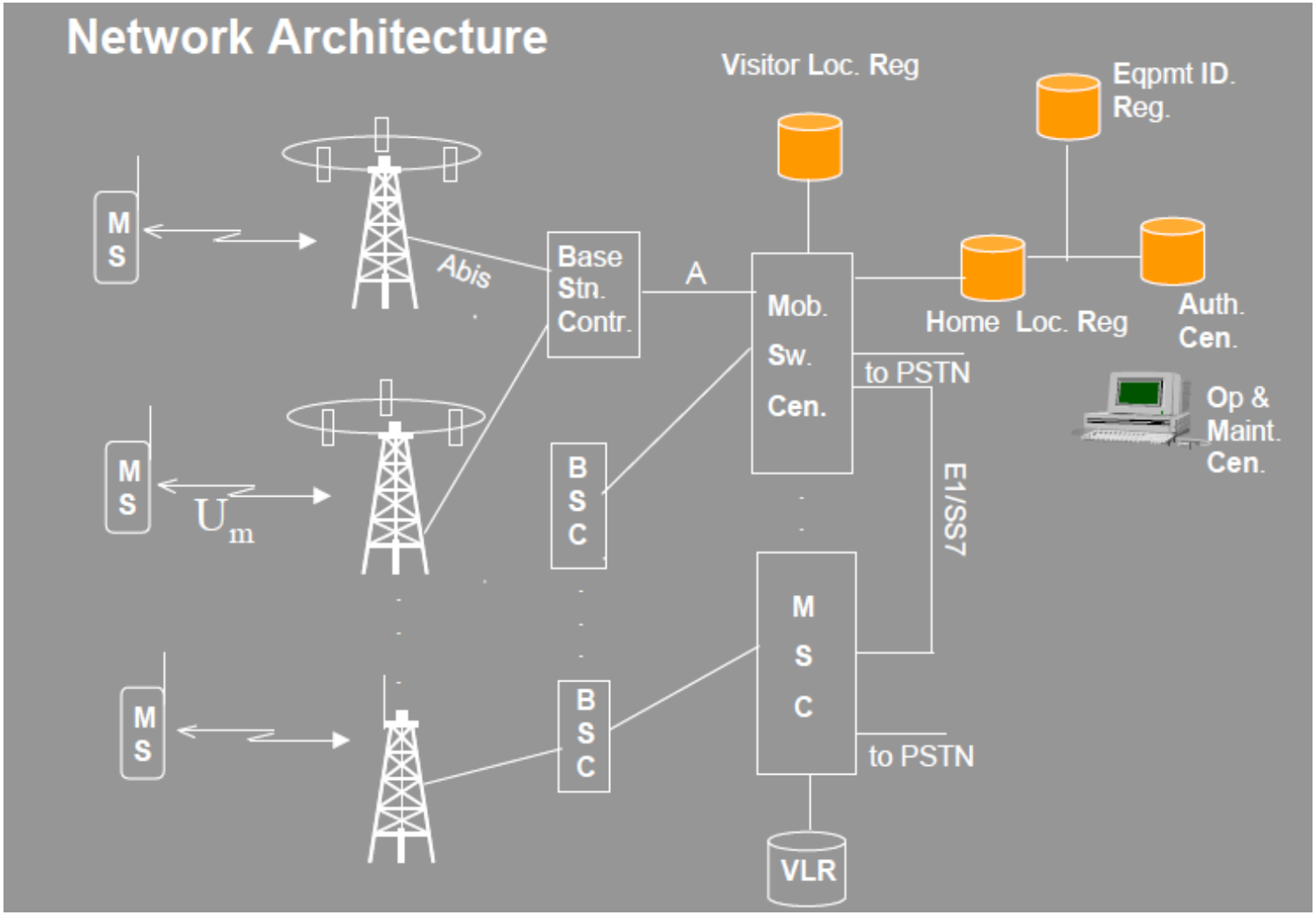
- Rappel de quelques notions de base
- Architecture et sécurité des réseaux de deuxième génération (GSM, GPRS)
- Architecture et sécurité des réseaux de troisième génération (UMTS)
- Architecture et sécurité des réseaux de quatrième génération (LTE)

Principales références

- **Xavier Lagrange, Philippe Godlewski et Sami Tabbane, Réseaux GSM , Hermes, 5 éme edition, 2000, ISBN 2-7462-0153-4**
- **Xavier Sanchez, Hamadou Thioune, UMTS, Hermes,2 eme édition 2004. ISBN 1-905209-71-1**
- **Yannick Bouguen, Éric Hardouin, François-Xavier Wolff, LT, E et les reseaux 4G, EYROLLES, 2012, ISBN : 978-2-212-12990-8**
- **Dan Forsberg, Günther Horn, Wolf-Dietrich Moeller and Valtteri Niem, LTE Security, John Wiley & Sons, 2011 , ISBN 978-1-118-35558-9**
- Bertrand Morel, Jean-Philippe Pastré, K Bedoui: Présentation de l'UMTS France Télécoms Orange
- Cours GSM/GPRS disponible sur : http://fr.slideshare.net/Garry54/gsm-4449773
- C. Demoulin, M. Van droogenbroeck. Principes de base du fonctionnement du réseau GSM. Revue de l'AIM, pages 3–18, N04, 2004
- …

Réseaux GSM

Architecture



BSS NSS

Réseaux GSM

- **Réseau dédié aux mobiles:(Public Land Mobile Network)**
  - Sous-systèmes radio (BSS: Base Station Sub-system)

    Réseau d'accès

  - Sous-systèmes réseau (NSS: Network Sub-System)

    Commutateurs spéciaux

    Bases de données

    Accès radio au Réseau Téléphonique Commuté Public

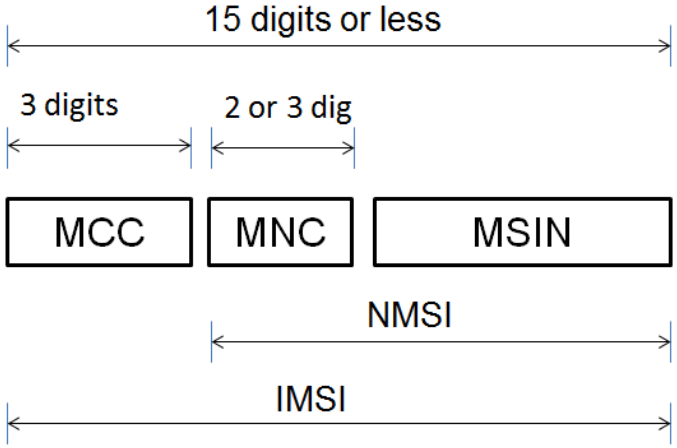
  - Sous-système d'exploitation (OSS: Operation Sub-System)

Station Mobile (Equipement mobile +SIM)

- **IMEI (International Mobile Equipement Identity)**
  - Identité du terminal (15 digits)

- **MSISDN (mobile Station ISDN Number)**
  - Identité pour le monde extérieur (seul le HLR connait MSISDN<-> IMSI)

- **IMSI (International Mobile Subscriber Identity):**
  - **Identité invariante de l'abonné:** Mobile country code (FR:208)
    Mobile network code (PLMN code FT:01, SFR:10)



Equipement Mobile: Gestion de puissances

Classe	Puissance Max (W)
I	20
II	**8**
III	5
IV	2
V	**0,8**

Sensibilité:

entre **-102** et **-104 dbm**

Sur demande du réseau, le mobile peut augmenter ou diminuer son émission par pas de 2 dBm toutes les 60 ms

Mesure	2	3	4	5	…	16	17	18	19
Watts	8	5	3.16	2	…	0.012	0.007	0.005	0.003
dBm	39	37	35	33	…	11	9	7	5

Exemple: Gestion de puissances sur la bande des 900 MHz

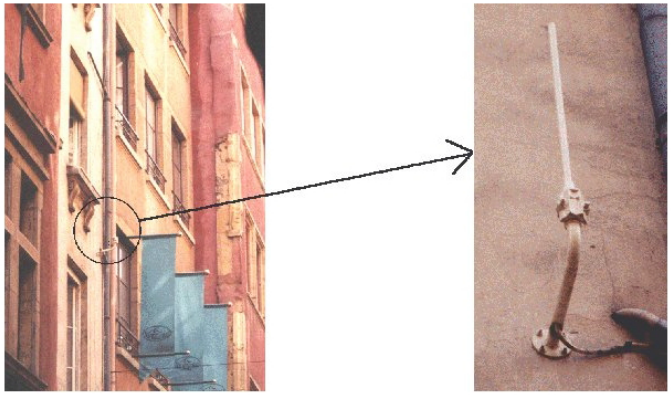
Sous Système Radio BSS: BTS

- Emetteurs récepteurs (TRX) avec un minimum d'intelligence
- Multiplexage TDMA, modulation, démodulation, codage, etc.
- Mesures radio (sans exploitation de ces mesures)
- Lien entre le mobile et le BSC
- Un TRX = 1 porteuse = 7 communications
- Rural BTS=1 TRX, Urbain BTS=2-4 TRX, max=16

Sous Système Radio BSS: BTS

- **BTS Standards (2,5-320 Watt)**
  - Locaux techniques
  - Antennes + câbles + 1-4 TRX, etc.
  - Sensibilité (-104 dBm)

- **Micro-BTS (0.01-0.08 Watt)**
  - Zone urbaine dense
  - Equipement intégré, coût faible
  - Sensibilité (-87 dBm, -97dBm)



Micro BTS (rue Mercière à Lyon, Rhône, France)

Sous Système Radio BSS: BSC

- Equipement intelligent du BSS
- Allocations des canaux (fréquences+slot)
- Contrôles de puissance des BTS et des mobiles en fonction des mesures de la BTS
- Prise de décision d'un handover

Pour Paris intra-muros quelques dizaines de BSC

Sous Système Réseau NSS: MSC / VLR

- Commutateur du service mobile
- Communication mobile ↔ autre MSC
- Fonction de passerelle avec le RTC

- Handover entre zones de localisation
- Gère le VLR pour la mobilité des usagers (identité temporaire)

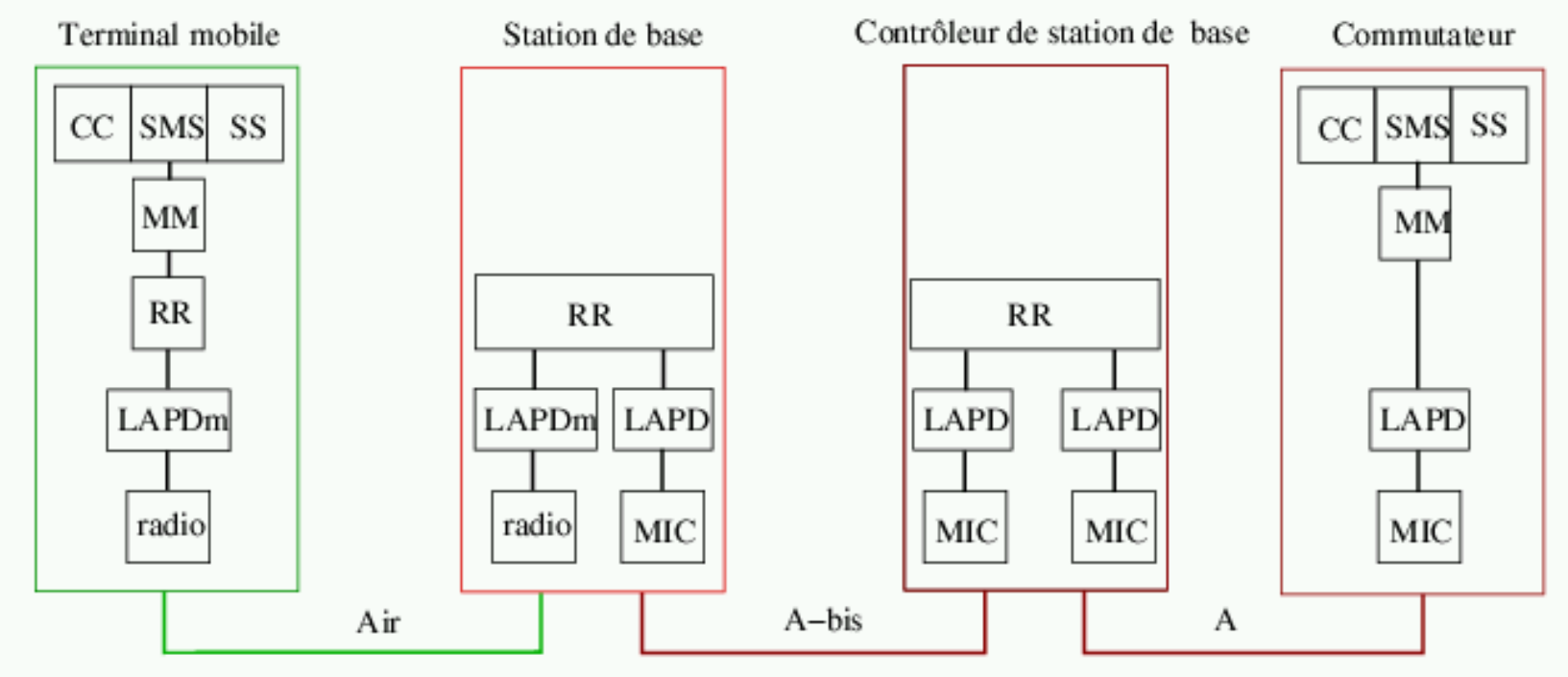
Sous Système Réseau NSS: HLR

- Mémorise les caractéristiques d'un abonné
  - Identification internationale (IMSI)
  - Numéro d'annuaire d'abonné (MSISDN)
  - Profil d'abonnement
- Mémorise le VLR où l'abonné est connecté
- Centralisé ou non

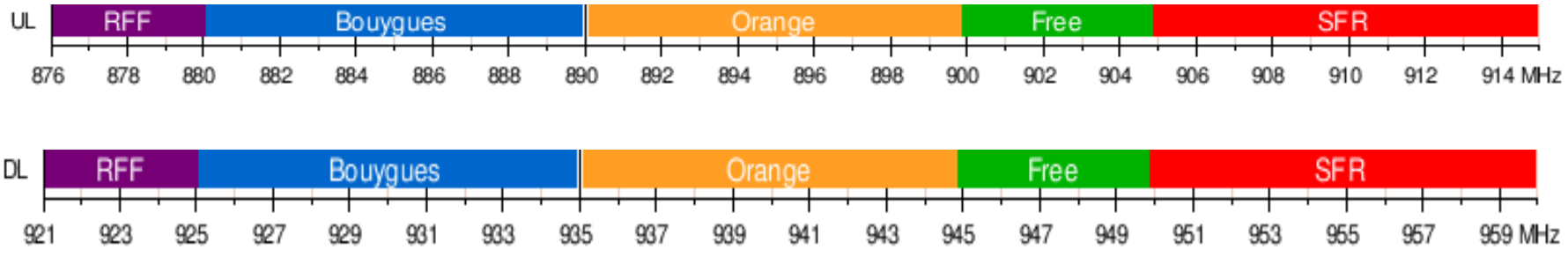
Sous Système de Maintenance: OSS

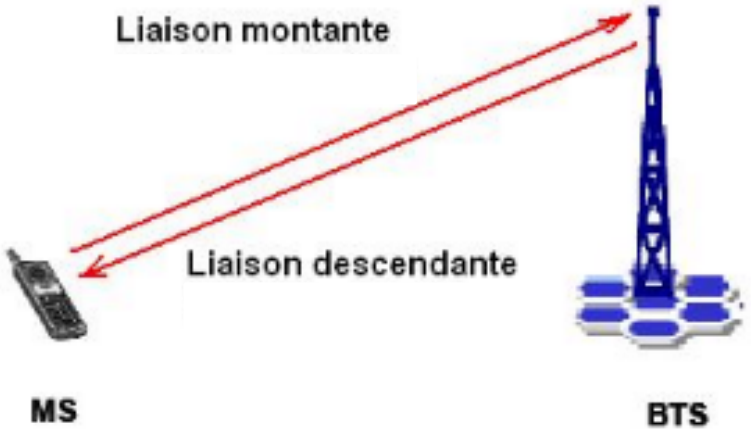
- Contrôle de performances
- Administration commerciale
- Maintenance
- **Gestion de la sécurité (Auc)**
- **Equipement Identity Register (EIR)**
  - Base de données de l'identité des terminaux
  - Contrôle homologation, déclaration de vol...

Architecture protocolaires



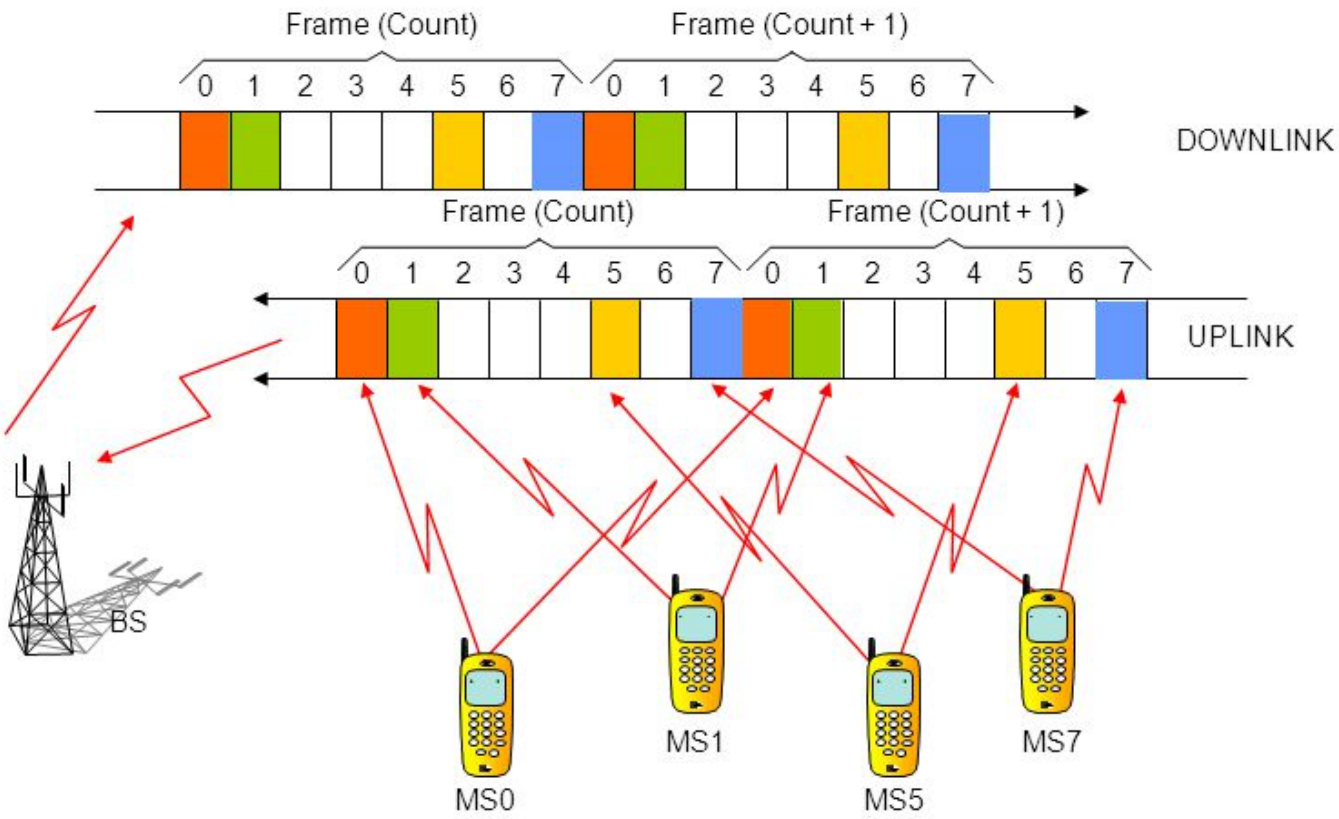
Ressources Radio: Partage des fréquences





Largeur des canaux étant de **200 kHz**
GSM : initialement **124** paires de porteuses

Ressources Radio: Partage en temps



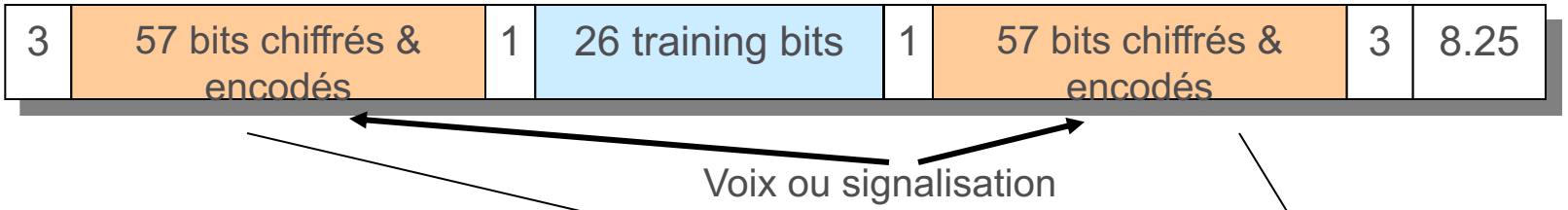
Slots: chaque porteuse est divisée en intervalles de temps appelés slots d'une durée de 577 us

Trame TDMA: les slots sont regroupés par paquets de 8 (4,615ms)

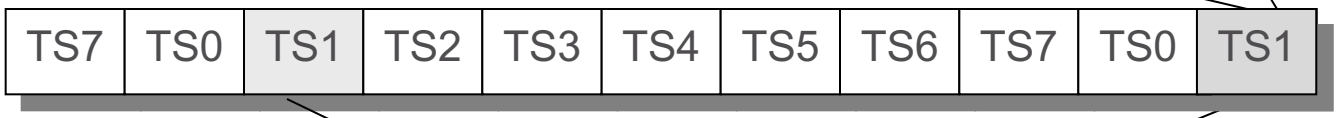
Canal physique: répétition périodique d'un slot sur une fréquence

Transmission sur le lien radio

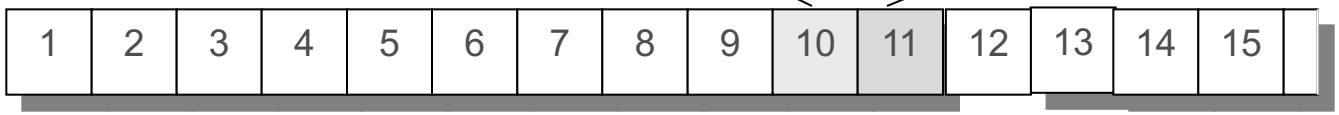
GSM slot : 156.25 bits (0.577 ms)



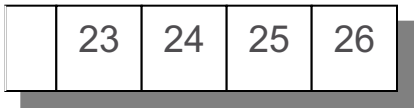
TDMA frame (4.615 ms):



TDMA multiframe:



= 26 or 51 TDMA frames (~120 ms or ~240 ms)



Transmission sur le lien radio

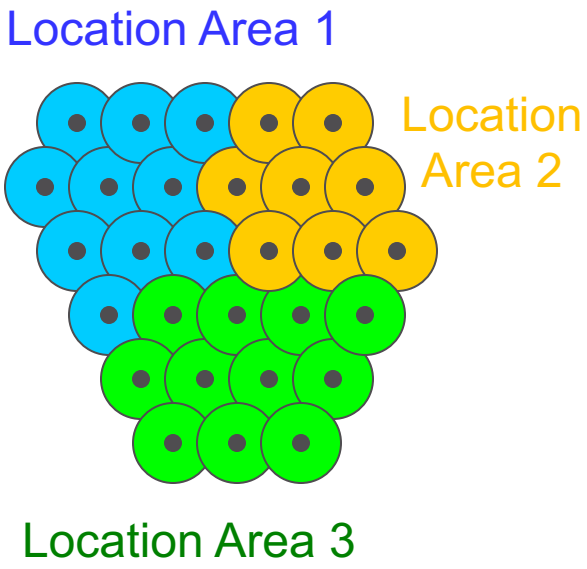
- Le codec GSM de parole délivre 260 bits de voix non protégée par 20 ms (13kbps)
- Le codage de canal génère 456 bits de voix protégée (22.8kbps): ajout de la redondance afin de protéger contre le bruit et les erreurs
- 4 burst (114*4) sont nécessaires pour transmettre la voix protégée générée pendant 20ms
- 24 burst sont donc nécessaire pour transmettre la voix protégée générée pendant 120 ms
- Dans une multi-trame de 26 burst, le burst 12 est réservée au contrôle de la puissance, qualité du lien, etc (canal SACCH)

Zones de localisation

– **Localisation**: Savoir où se trouve le mobile a tout moment

– **Recherche**: Emettre des messages d'avis de recherche dans les cellules « paging »

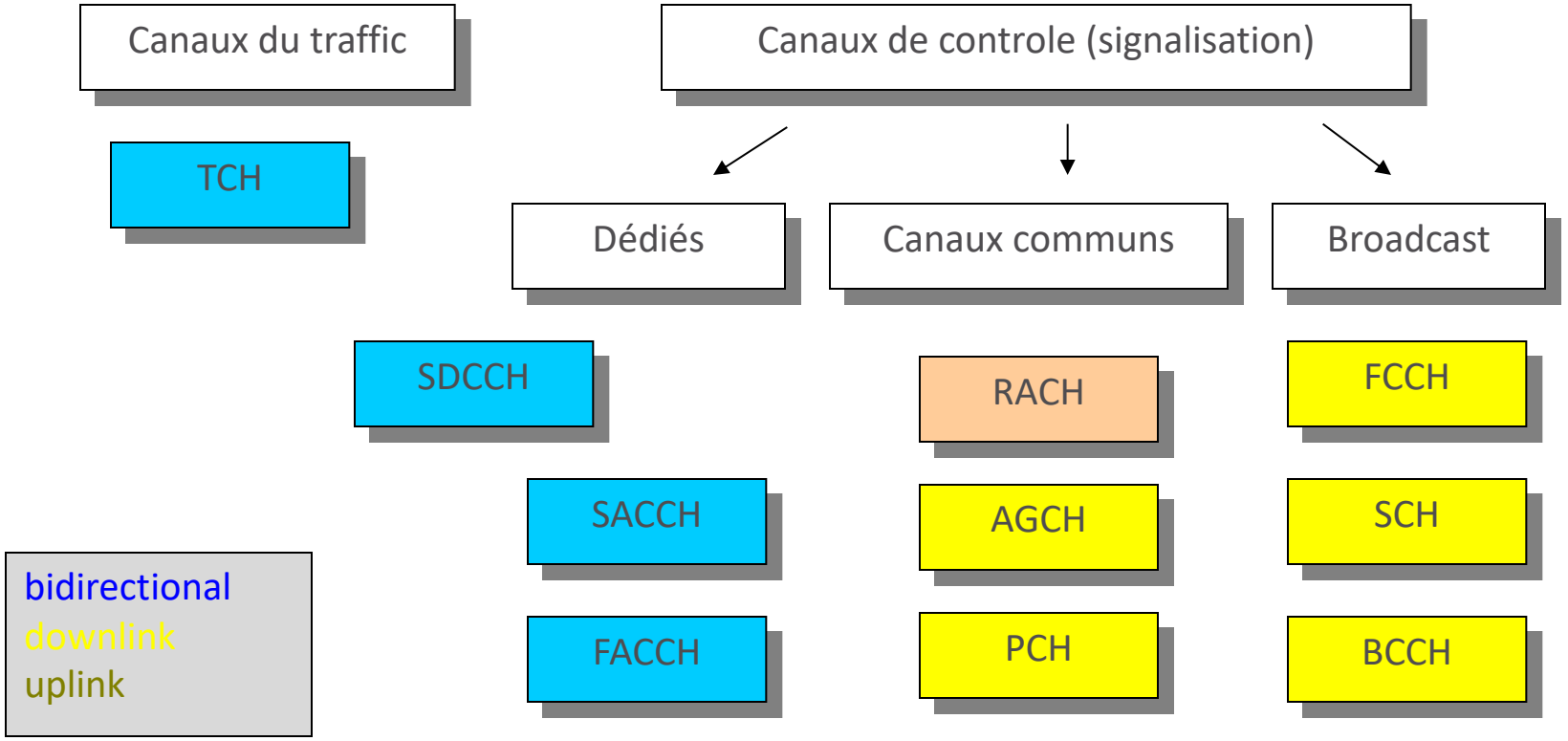
Le réseau GSM est divisé en zones de localisation (LA), Chacune englobe un nombre de BTS et elle est identifiée par un LAI



Une MS qui change de zone de localisation doit mettre à jour sa zone de localisation (location update)

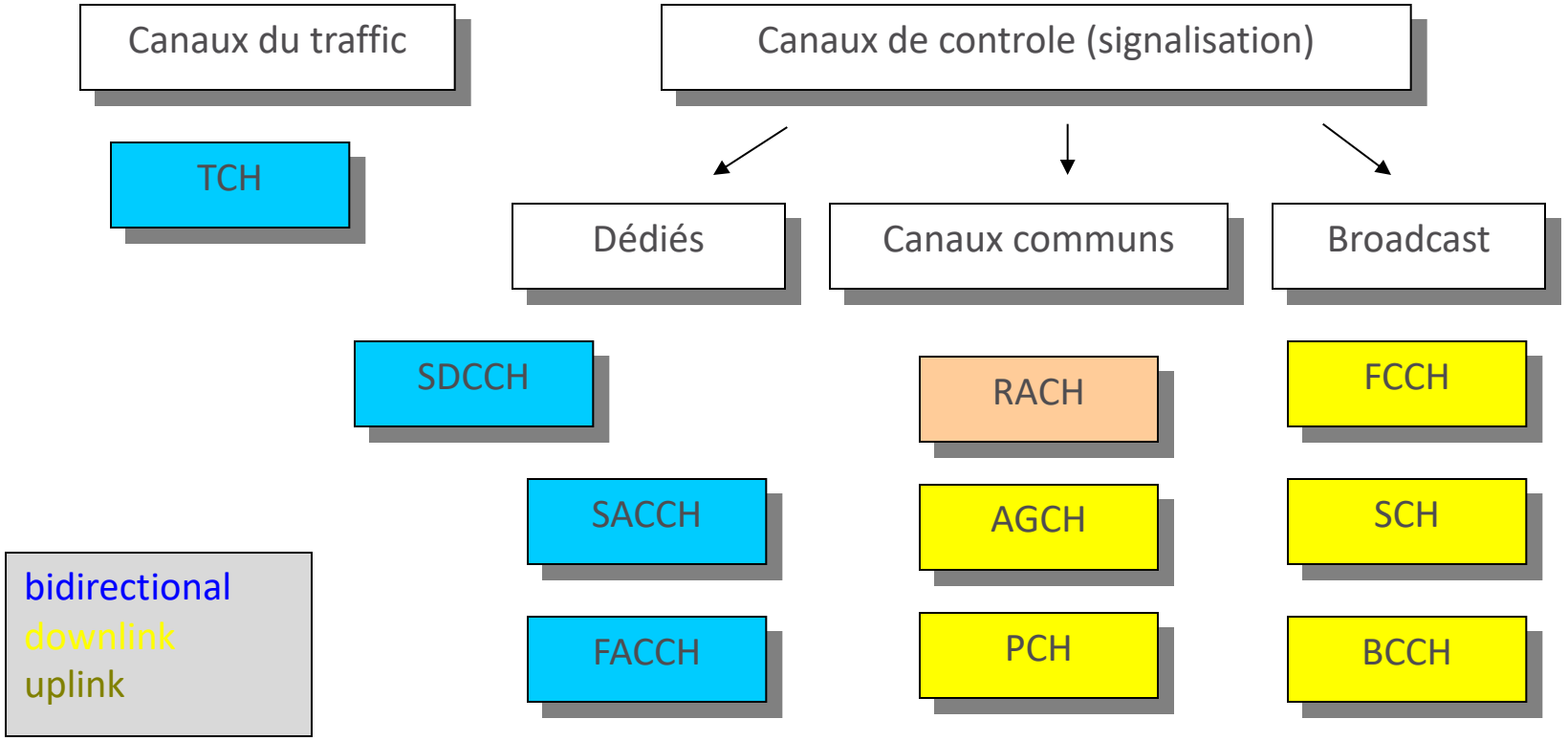
LA de grande taille Vs petite taille
- Mise à jour de zone de localisation
- Surcoût du paging

Canaux logiques



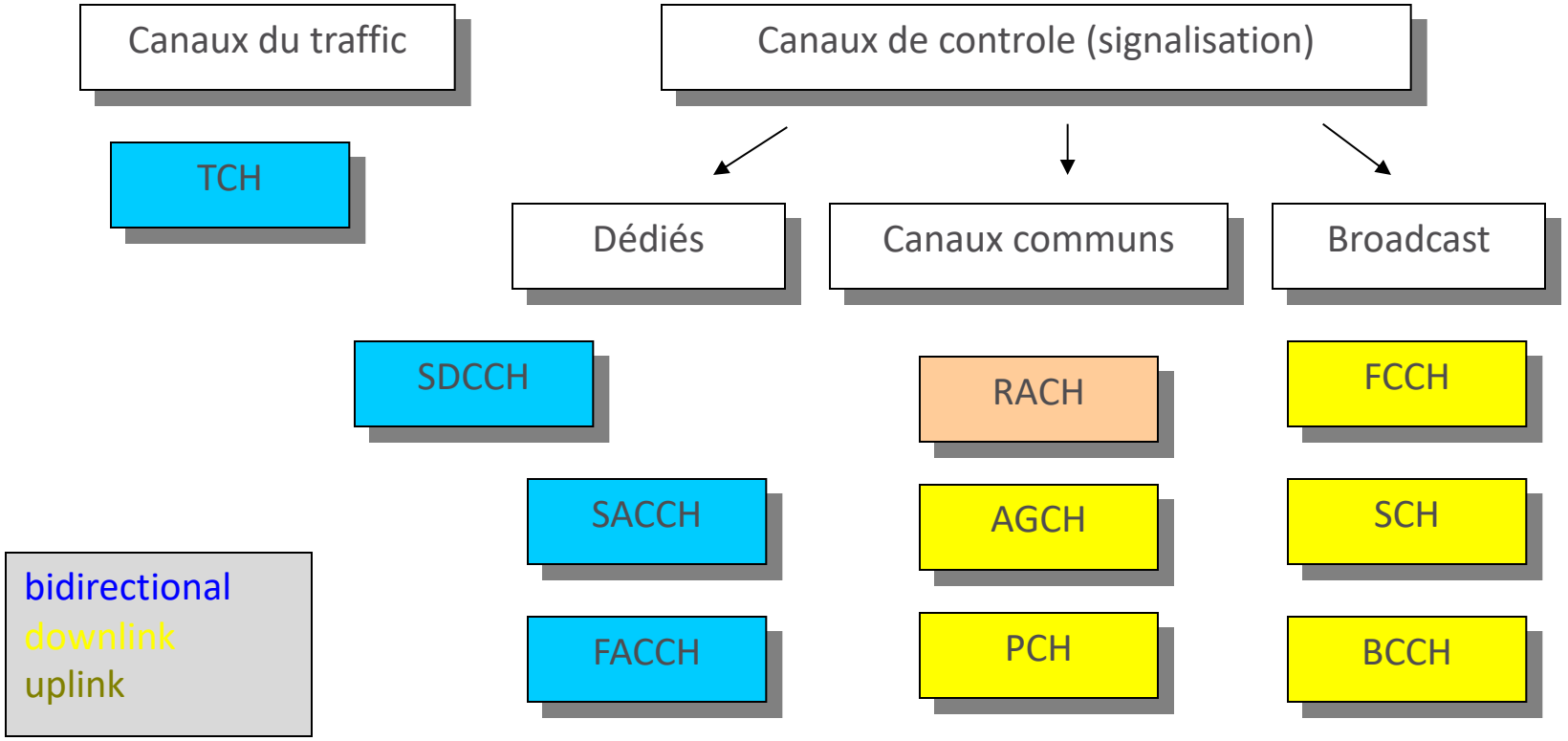
TCH (Traffic Channel): La parole (13 kbps ou 5,6 kbps)
SDCCH (Stand-alone Dedicated Control Channel): Signalisation (800 bps)
Mise à jour de localisation , IMSI Attach, IMSI Detach, Initiation d'appel.,SMS, etc.

Canaux logiques



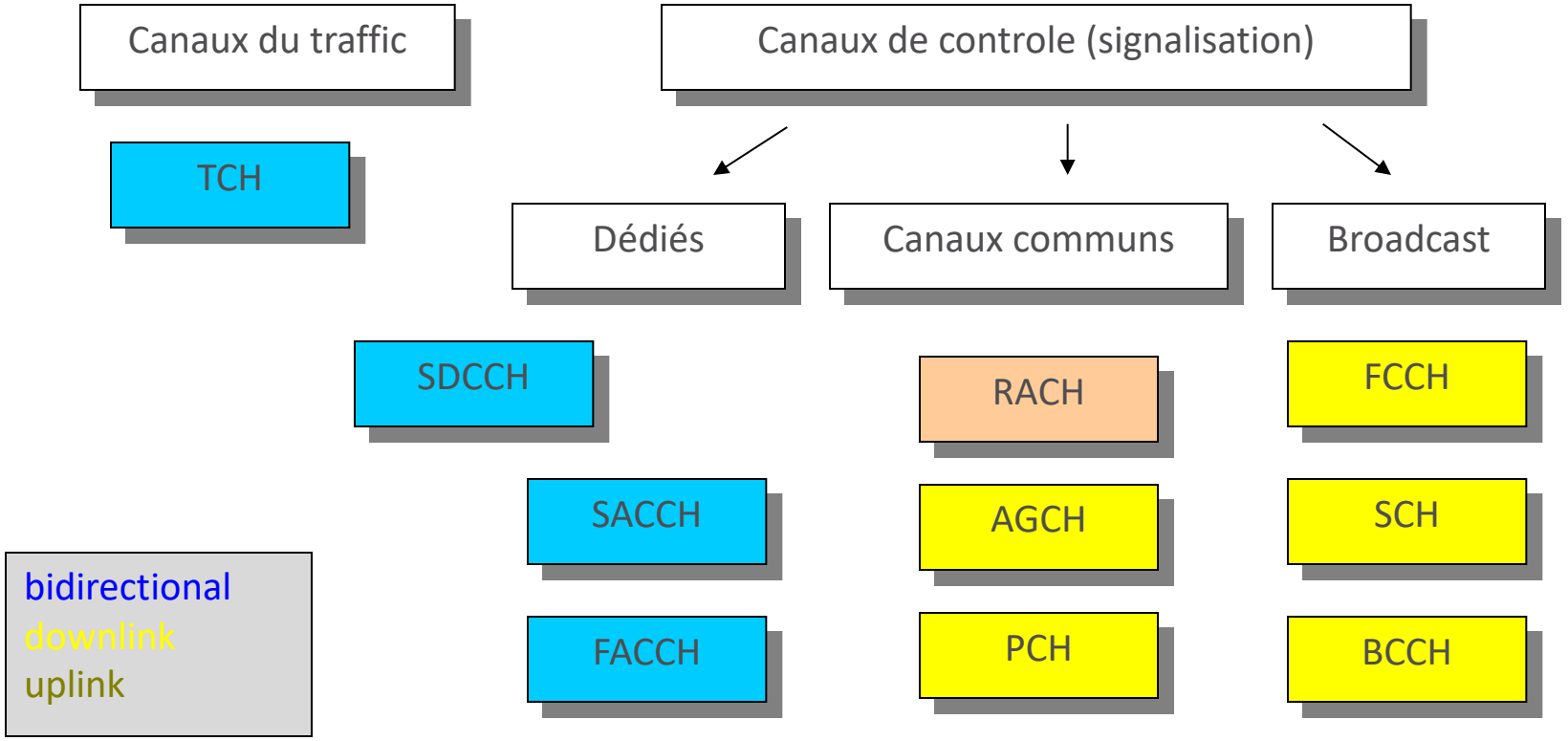
SACCH (Slow Ass. Control Channel): associé au TCH ou SDCCH, contrôle de la puissance d'émission, qualité du lien, mesures sur les stations voisines, etc.
FACCH (Fast Ass. Control Channel): associé au TCH ou SDCCH, contrôle ou signalisation rapide: Handover

Canaux logiques



RACH (Random Access Channel): Mode ALOHA, s'enregistrer, lancer un appel
AGCH (Access Grant Channel): Allocation d'un canal dédié
PCH (Paging Channel): Paging

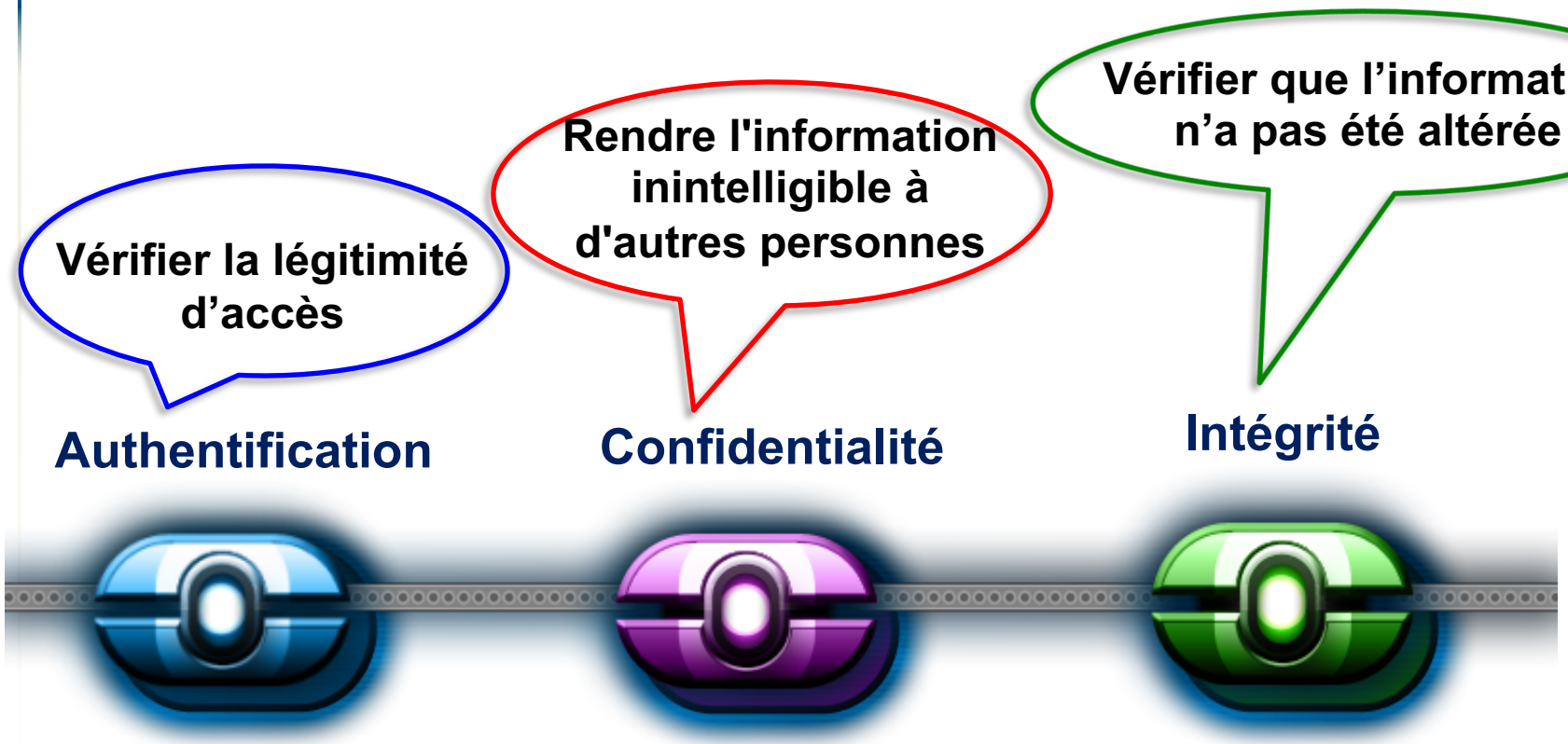
Canaux logiques



FCCH (Frequency cor. Channel): 148 bits à 0 chaque 50ms, calage fin de l'oscillateur
SCH (Synchronisation Channel): Synchronisation sur la trame de la SB
BCCH(Broadcast Control Channel): Informations de la cellule: Cell Identity, numéro de zone de localisation , description et organisation des canaux, etc.

Sécurité GSM

Rappel: services de sécurité

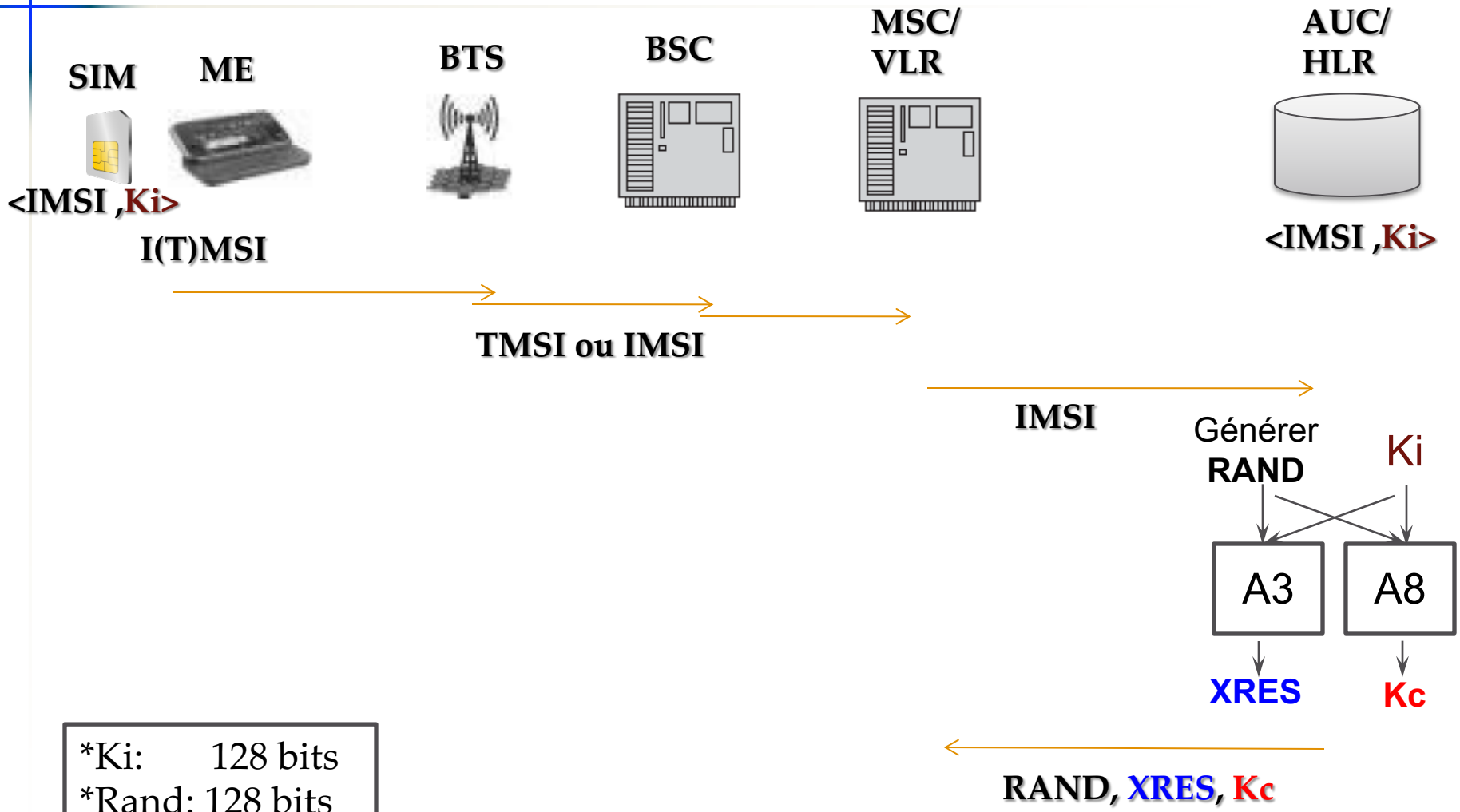


Sécurité GSM

- **Vulnérabilité des communications radio → Besoin de**
  - Confidentialité de l'IMSI
  - Authentification
  - Confidentialité des données de trafic et de signalisation
  - Intégrité !
- **Les réseaux GSM assurent:**

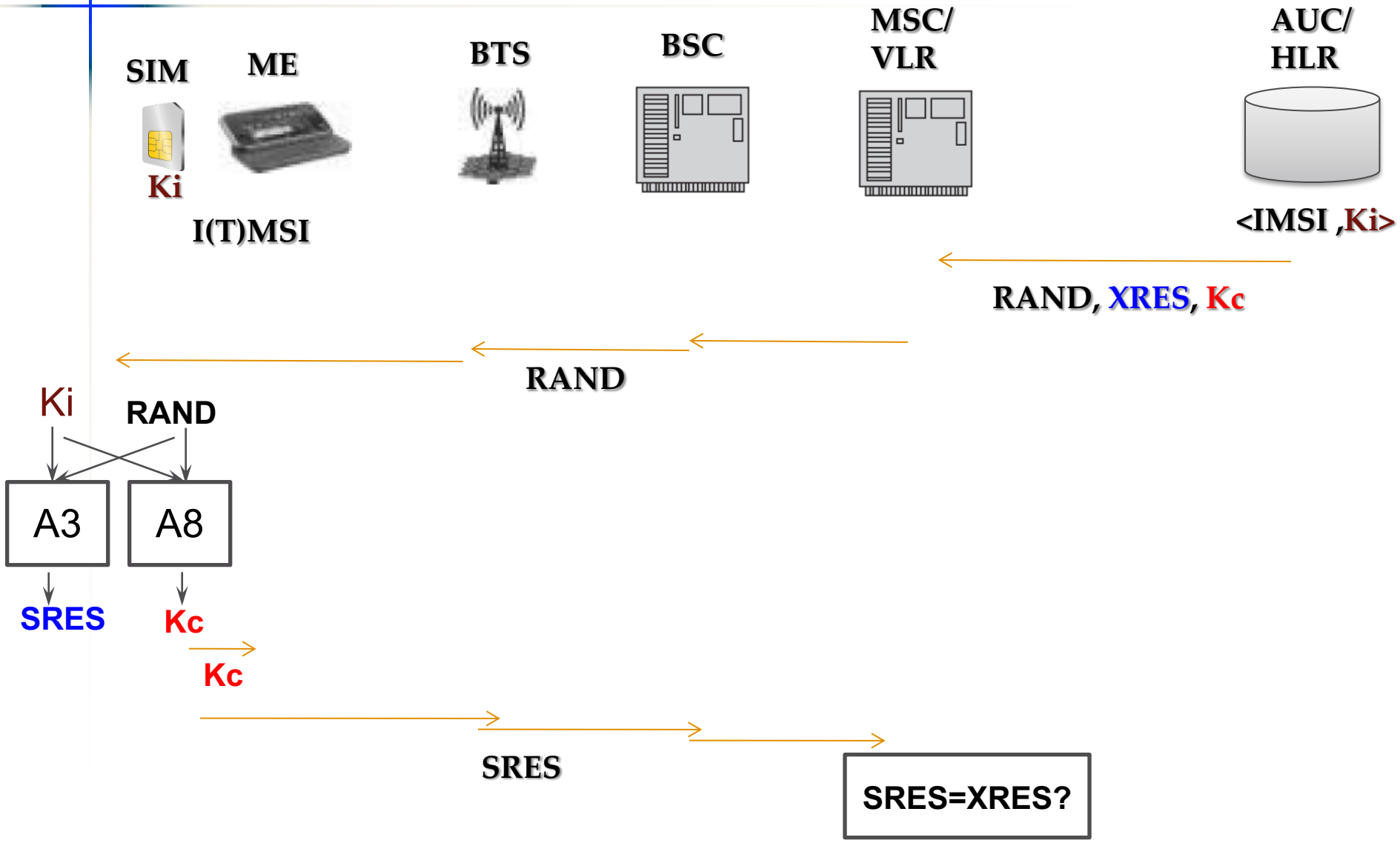
- La gestion des vols des équipements usagés
- Utilisation d'une identité temporaire TMSI attribuée par le VLR
- **Authentification** de chaque abonné auprès du réseau
- **Chiffrement** des communications entre le MS et la BTS

Authentification GSM

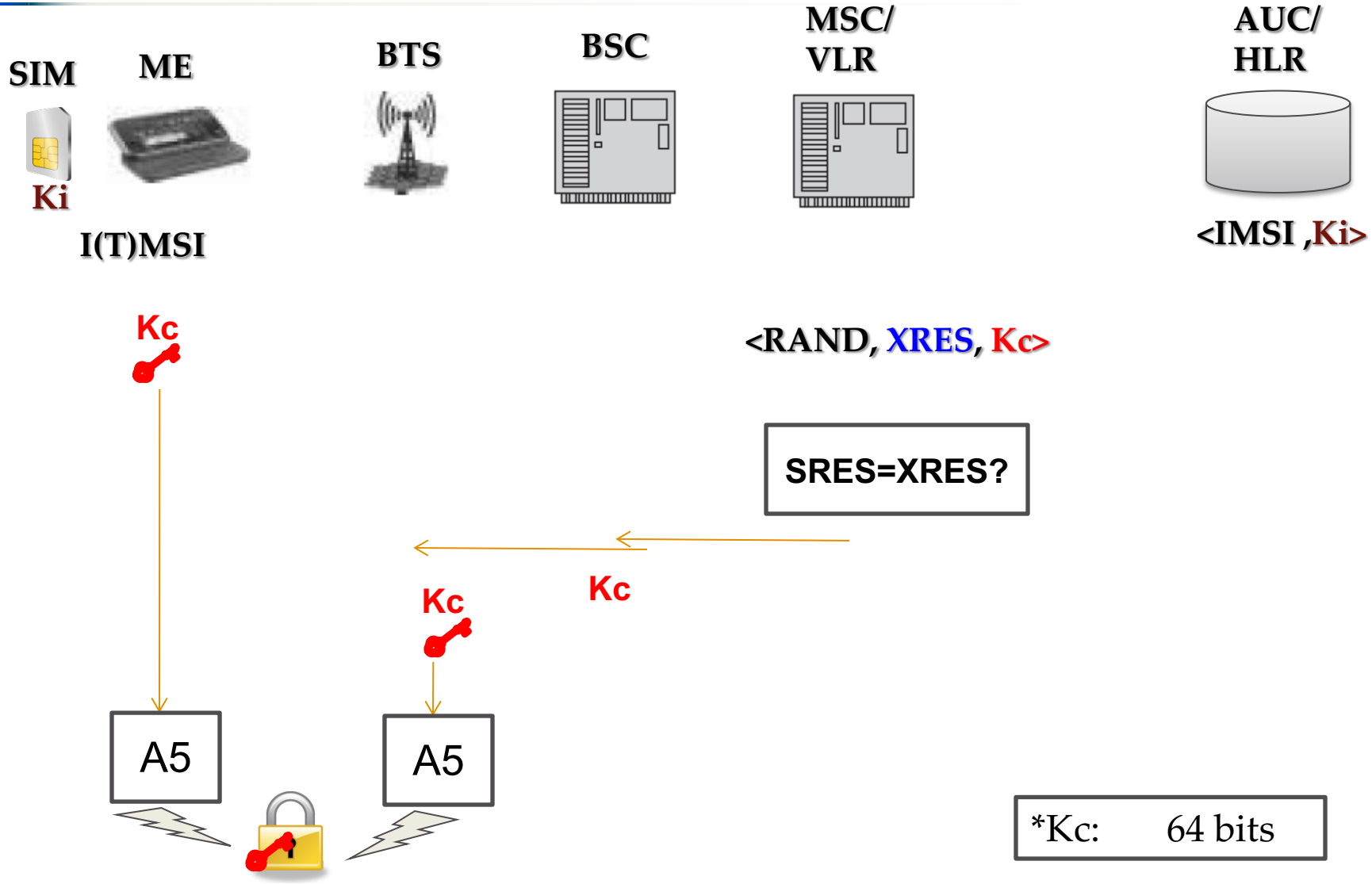


*Ki: 128 bits
*Rand: 128 bits
*XRES: 32 bits

Authentification GSM



Distribution de la clé de session



Authenfication des abonnés

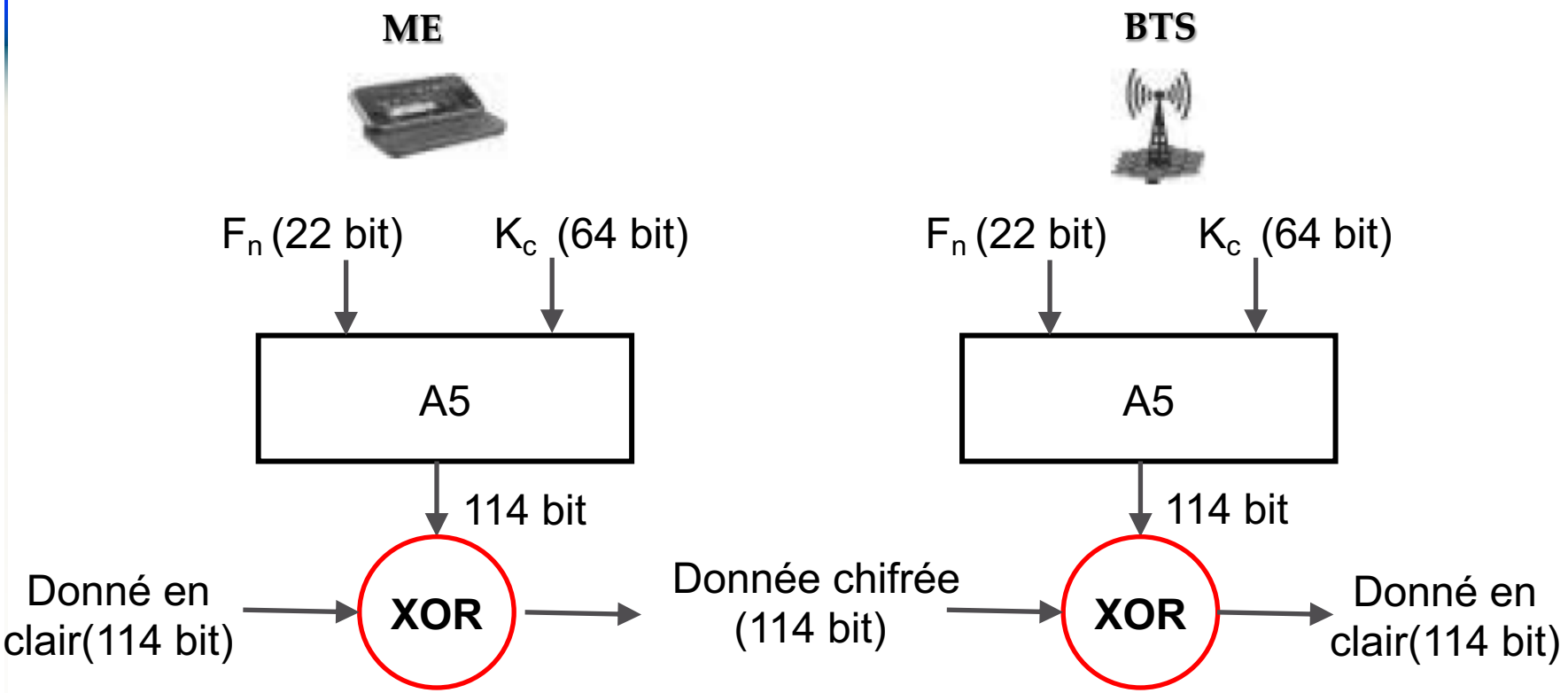
- L'authentification est déclenchée par le réseau:
  - L'abonné demande l'accès à un service (appel sortant, appel entrant, activation/ désactivation de services supplémentaires, etc.)
  - Premier accès après le démarrage du VLR/MSC
  - Mise à jour d'information de localisation , etc.

Algorithmes cryptographiques A3 et A8

- La carte SIM réalise le calcul A3 / A8 dans un espace sûr
- Même si la norme GSM ne recommande aucun algorithme, les opérateurs utilisent la procédure COMP128
- Les trois premières versions de COMP128 étaient initialement secrètes mais obtenues par «reverse engineering »

- Des chercheurs ont pu retrouver la clé grâce à environ 150 000 (challenge/response). Les algos COMP128 sont munis d'un compteur limitant le nombre de tentatives

Chiffrement de la voix en GSM (A5)



Fn: numéro de trame
Protocoles standardisés: A5/1, A5/2 (A5/0 no encryption)

Illustration du A5/1: https://www.youtube.com/watch?v=LgZAI3DdUA4

Sécurité : Quelques limites du GSM

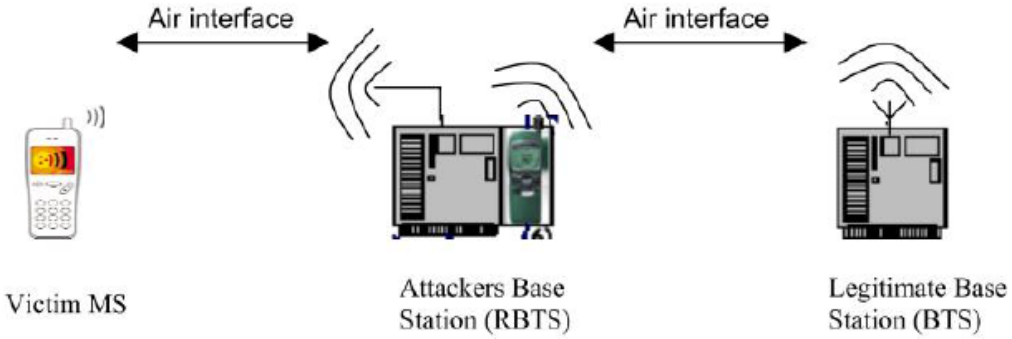
- **Les transmissions sont cryptées seulement entre MS et BTS**
- **Authentification dans un seul sens (BTS malveillante !)**
- **Les réseaux GSM n'assurent aucune intégrité des messages de contrôle ni de voix**

- MS doit répondre à toutes les requêtes rand
- La clé de session est envoyée en clair entre le MSC/VLR et la BTS
- Faiblesse des algorithmes A5/1 et principalement A5/2

Quelques attaques contre les réseaux GSM

- **BTS Malveillante**

  (Rogue base stations)

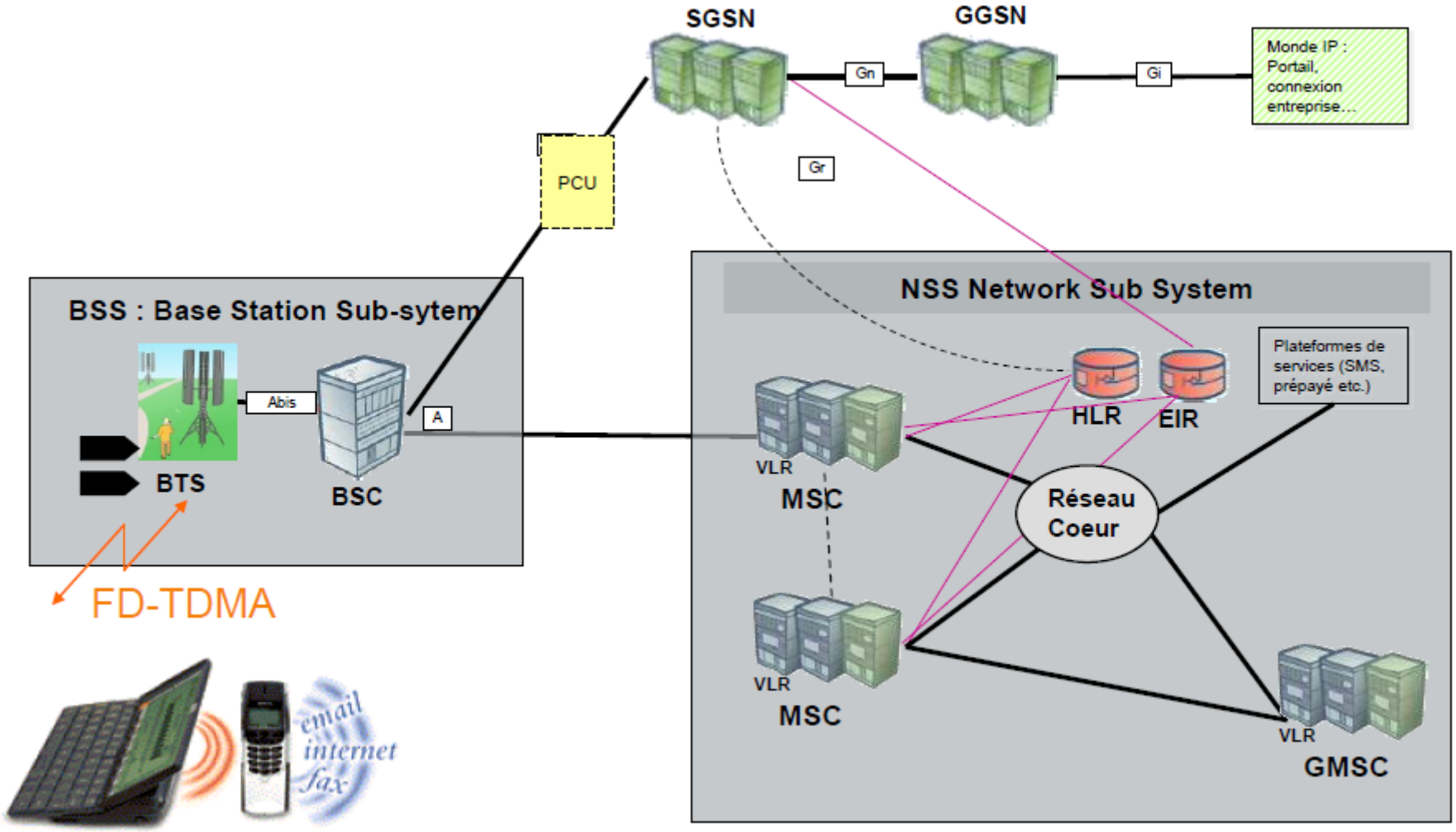


  Pas d'authentification mutuelle !

- **Attaques contre la confidentialité (retrouver Kc)**
  - Brute force 2^64 (réellement 2^54) (A5/1 → 2^40, A5/2 → 2^16)
  - Attaques par texte clair connu

- **Retrouver la clé K_i:**
  - Clonage physique des cartes SIM
  - Retrouver les K_i grâce aux challenges/responses

Evolution vers le GPRS (2.5 G)



* B Morel / JP Pastré, Réseau GPRS, France Télécom -Orange

Evolution vers le GPRS (2.5 G)

- **SGSN(Serving Gprs Support Node)**
  - Gère les échanges BSC <- -> Cœur du réseau (équivalent au MSC/VLR)
  - L'enregistrement et authentification GPRS, zones de routage (RAI)
  - L'établissement, le maintien et la libération des sessions de données
- **GGSN(Gateway Gprs Support Node)**
  - Passerelle d'interconnexion du GPRS vers les réseaux extérieurs
  - Allocation d'adresse IP au mobile (allocation dynamique)
  - Raccordement au réseau demandé
- **PCU (Packet Control Unit)**
  - Segmentation des trames
  - Correction d'erreur, acquittement des blocs et retransmissions
  - Gestion des files d'attente downlink

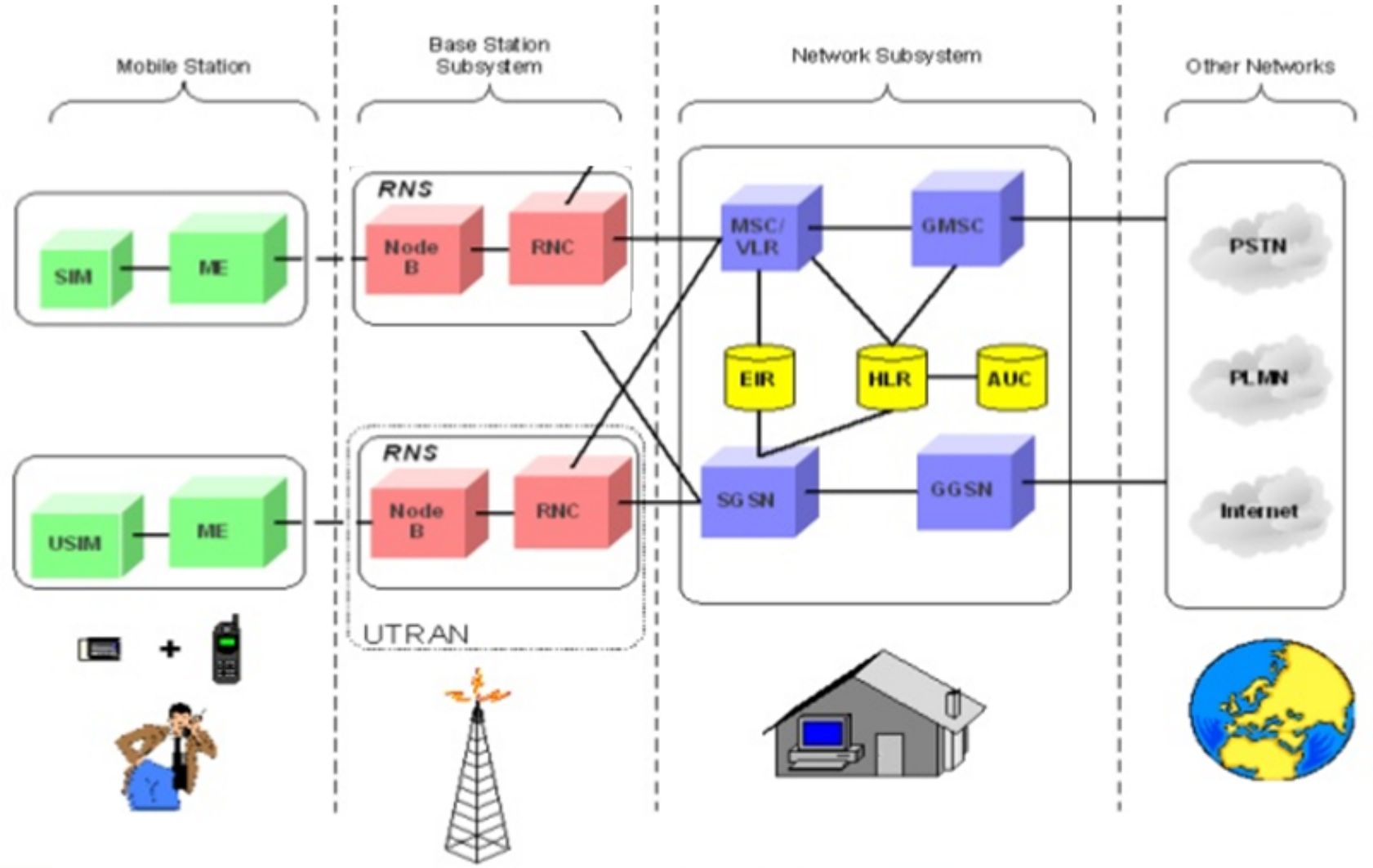
Sécurité dans les réseaux GPRS (2.5G)

- Attribution d'un identifiant temporaire P-TMSI par le SGSN
- Procédure d'authentification très similaire à celle du GSM (GPRS-Rand, GPRS-RES, GPRS-SRES)
- Génération similaire des clés de sessions GPRS-Kc

- Le chiffrement ne se fait plus au canal physique mais au niveau de la couche LLC (trame logique): avant segmentation des trames
- Le chiffrement se fait entre l'utilisateur et le SGSN
- Des algorithmes GEA (GPRS Encryption Algorithm) sont utilisés pour le chiffrement des paquets (très similaires aux algos A5)

Réseaux UMTS

Architecture Physique



* L. ELAABIDI, cours UMTS, Cynapsys Software Enginnering

UTRAN UMTS

- **Le réseau d'accès composé:**

– Node B (équivalent de la BTS en GSM)

– RNC (Radio Network Controller) équivalent du BSC en GSM

– Le réseau d'accès fournit les ressources radio et achemine les informations (signalisation et données) jusqu'au réseau cœur

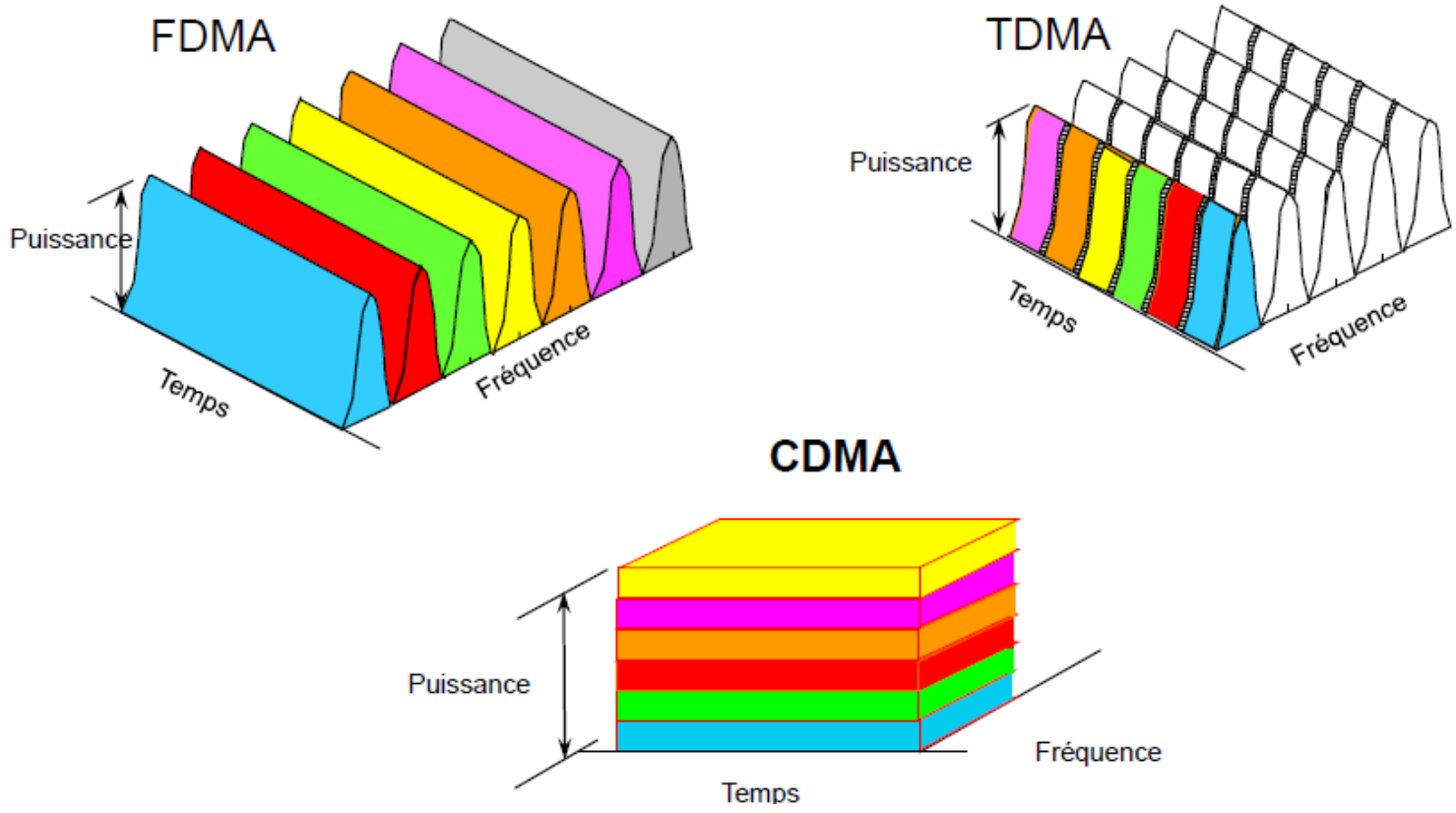
- **Réseau cœur :**

– Deux domaines: **domaine CS** (Circuit Switching) composé de MSC/VLR, GMSC et **domaine PS** (Packet Switching) composé de SGSNs et GGSNs

– Les équipements HLR, AUC et EIR sont communs aux 2 domaines

– Il assure les fonctions de contrôle d'appel et de sécurité, la gestion de l'itinérance et de l'accès aux réseaux externes

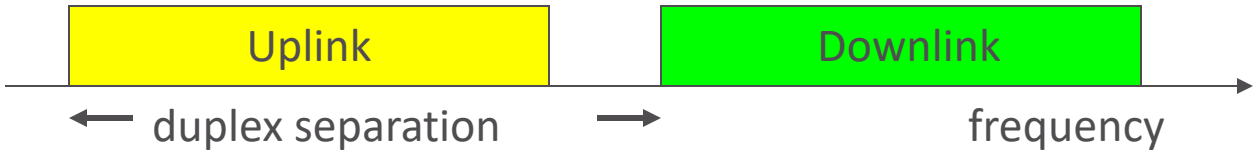
Evolution fondamentale: Accès au canal



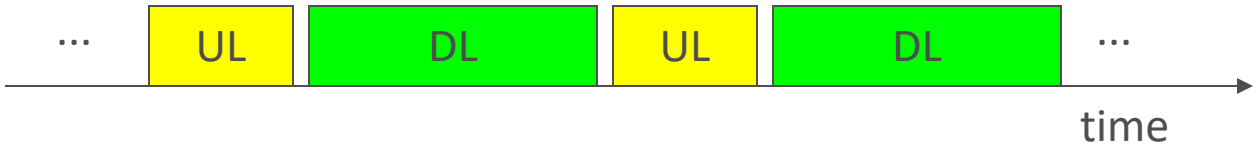
- **3G: Codage W-CDMA (Wideband Code Division Multiple Access)**

Evolution fondamentale: Duplexage

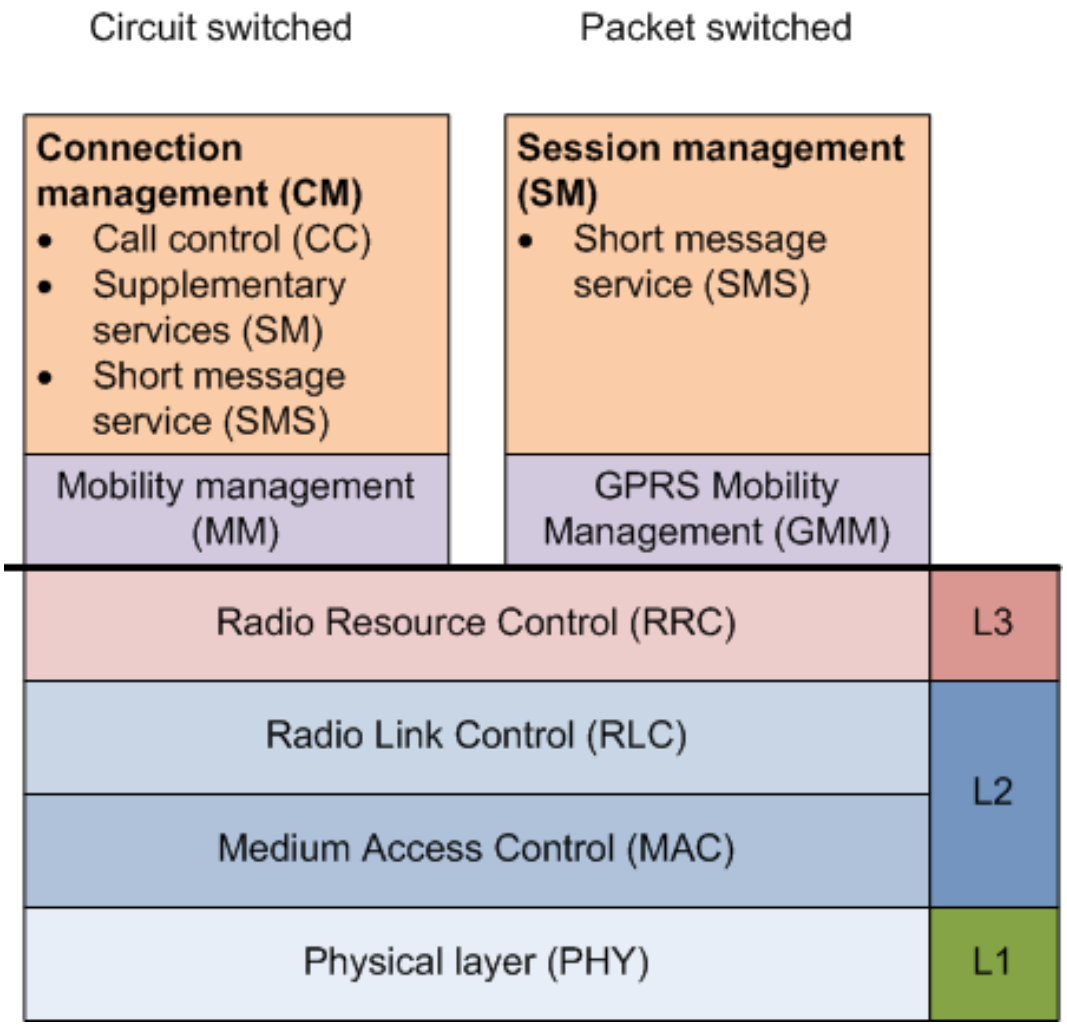
FDD (Frequency Division Duplexing)
(GSM/GPRS, UTRA FDD)



TDD (Time Division Duplexing)
(UTRA TDD)



Architecture protocolaire



* Naveen Jakhar, Radio and Core Network Protocols in UMTS, ITS

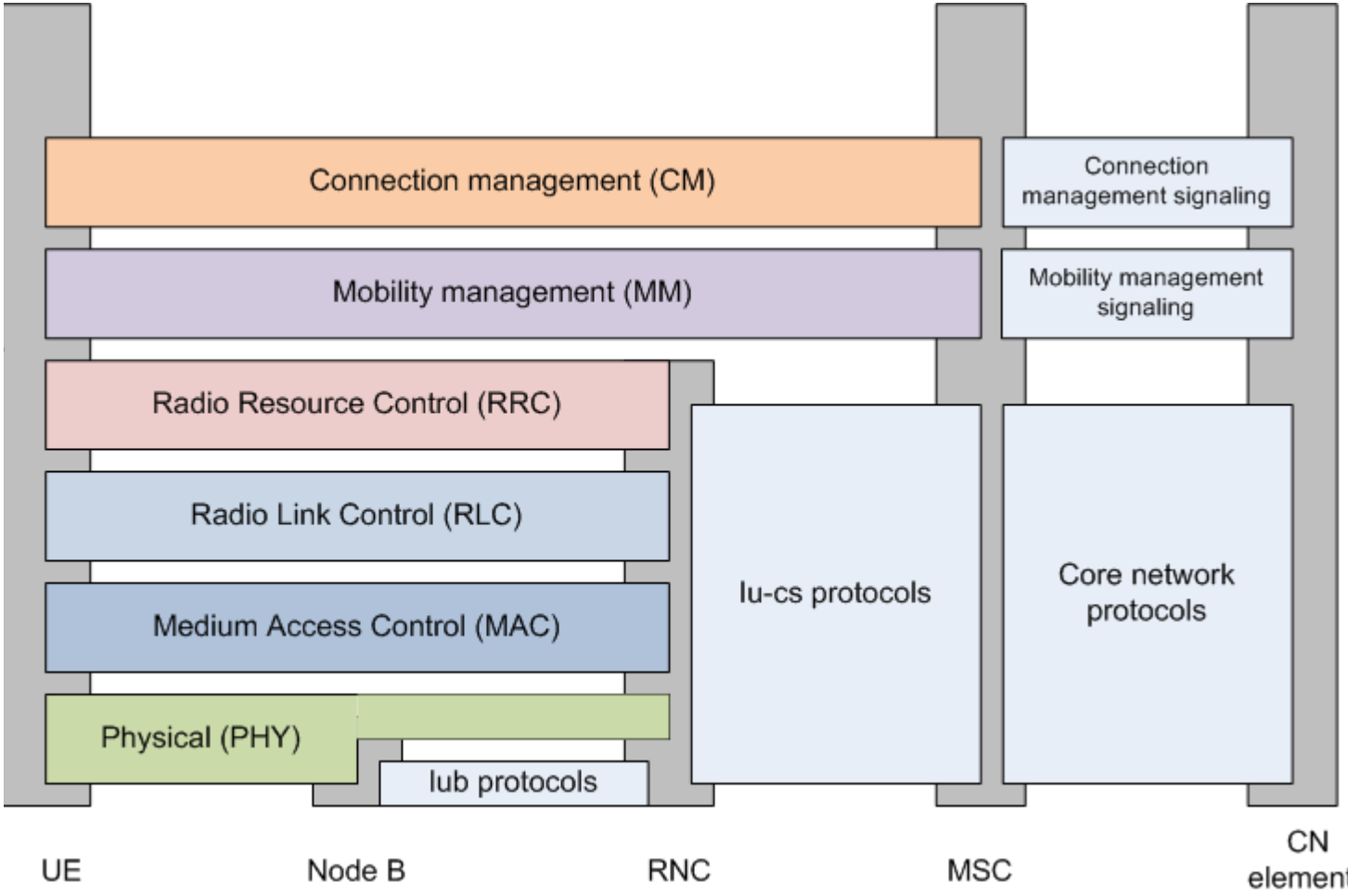
UTRAN UMTS

- **Couche RRC:**

– Gestion des connexions RRC, gestion du paging, (re)sélection des cellules, contrôle des mesures, etc.

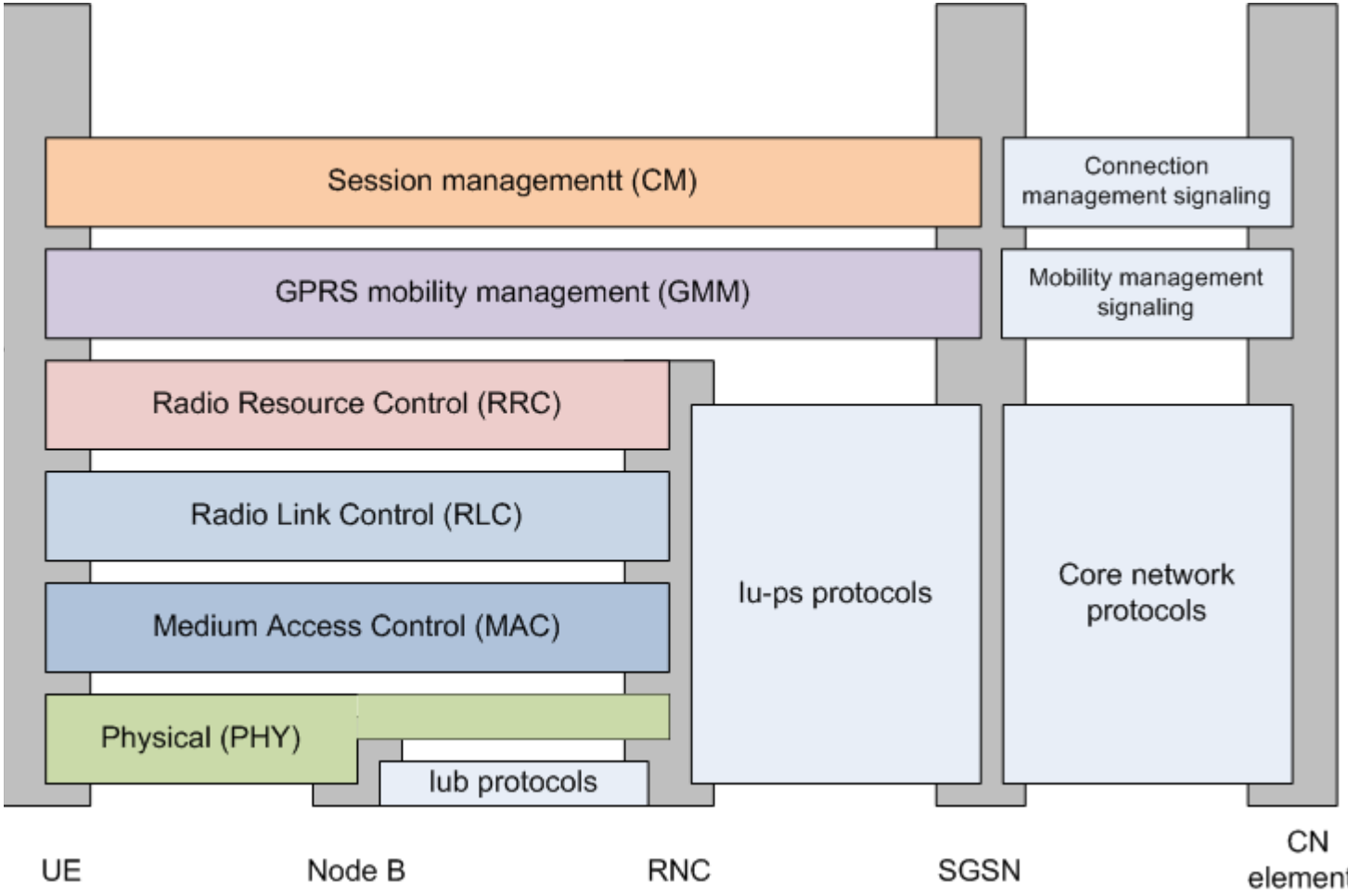
- **Couche RLC :**
  - **Mode transparent :** segmentation/réassemblage
  - **Mode non acquitté :** + numérotation + détection d'erreur sans reprise + cryptage + intégrité des paquets de contrôles
  - **Mode acquitté :** + retransmission + cryptage + intégrité des paquets de contrôles

Architecture protocolaire: Plan contrôle CS



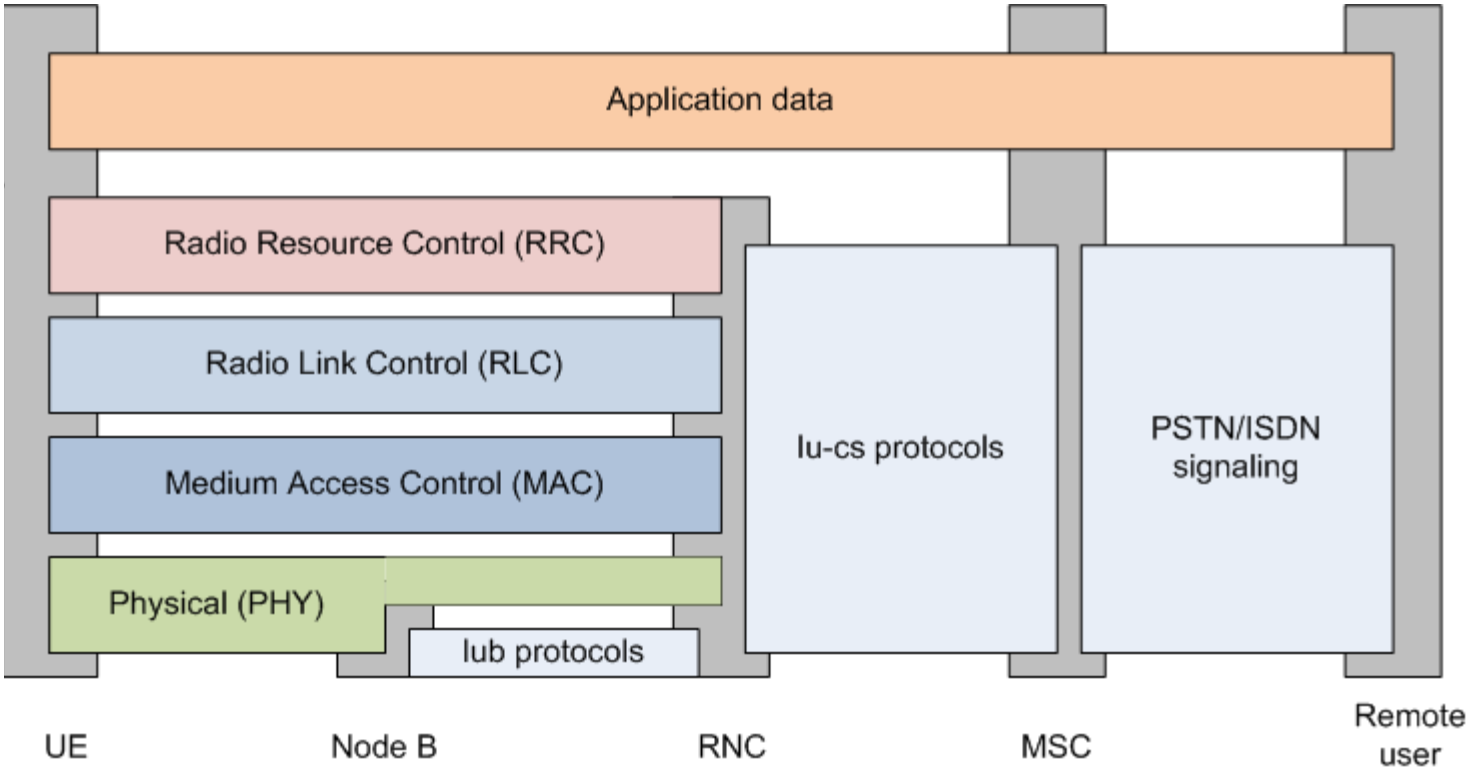
* Naveen Jakhar, Radio and Core Network Protocols in UMTS, ITS

Architecture protocolaire: Plan contrôle PS



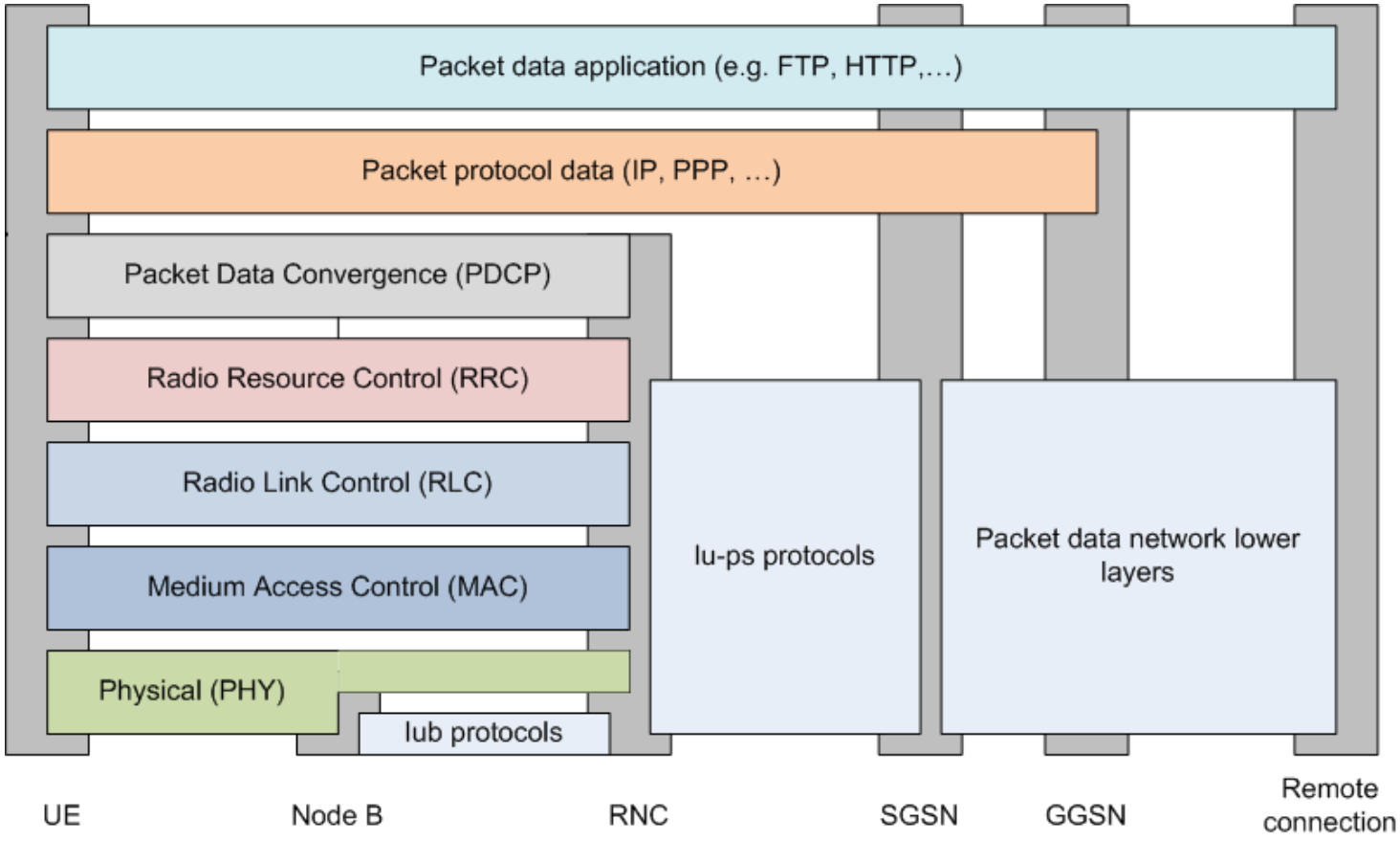
* Naveen Jakhar, Radio and Core Network Protocols in UMTS, ITS

Architecture protocolaire: Plan usager CS



* Naveen Jakhar, Radio and Core Network Protocols in UMTS, ITS

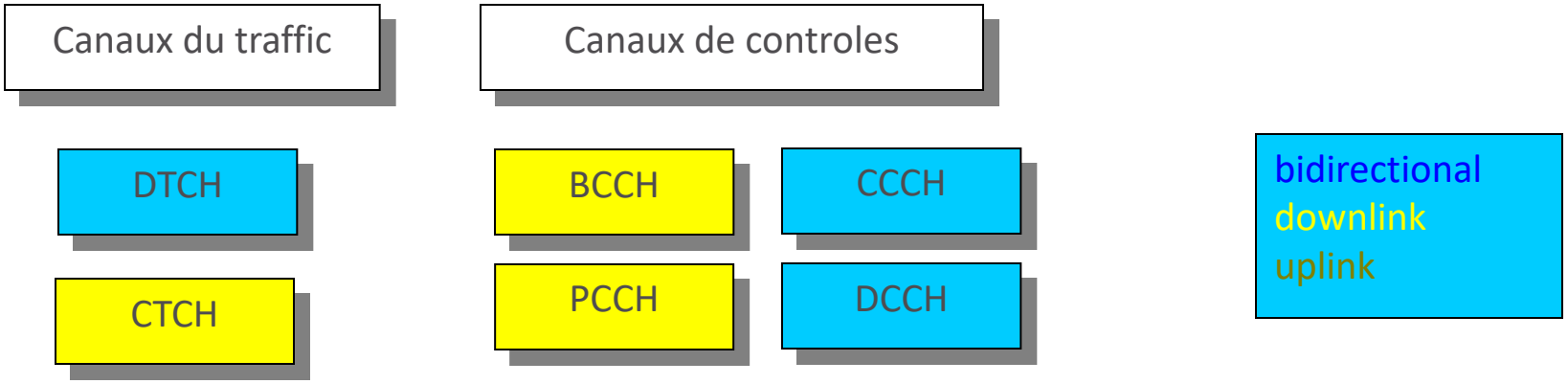
Architecture protocolaire: Plan usager PS



PDCP Couche facultative pour la compression des entetes

* Naveen Jakhar, Radio and Core Network Protocols in UMTS, ITS

Canaux logiques



- DTCH : Transfert de données spécifiques à 1 MS
- CTCH : Transfert de données usager vers un ensemble de MS.
- BCCH : Diffusion permanente d'informations système
- PCCH : Envoi des messages de paging à destination des MS
- CCCH : Transmission de message de signalisation entre les MS et le réseau
- DCCH : Transmission de message de signalisation entre un MS et le réseau

Sécurité UMTS: principales nouveautés

- Authentification mutuelle
- Intégrité des échanges du plan contrôle
- Chiffrement entre UE et RNC (et non pas le nodeB)

- Nouveaux algorithmes pour la confidentialité et l'intégrité (UEA, UIA)
- Utilisation des clés de 128 bits (C_K et I_K)
- Utilisation des algorithmes publics

Sécurité UMTS

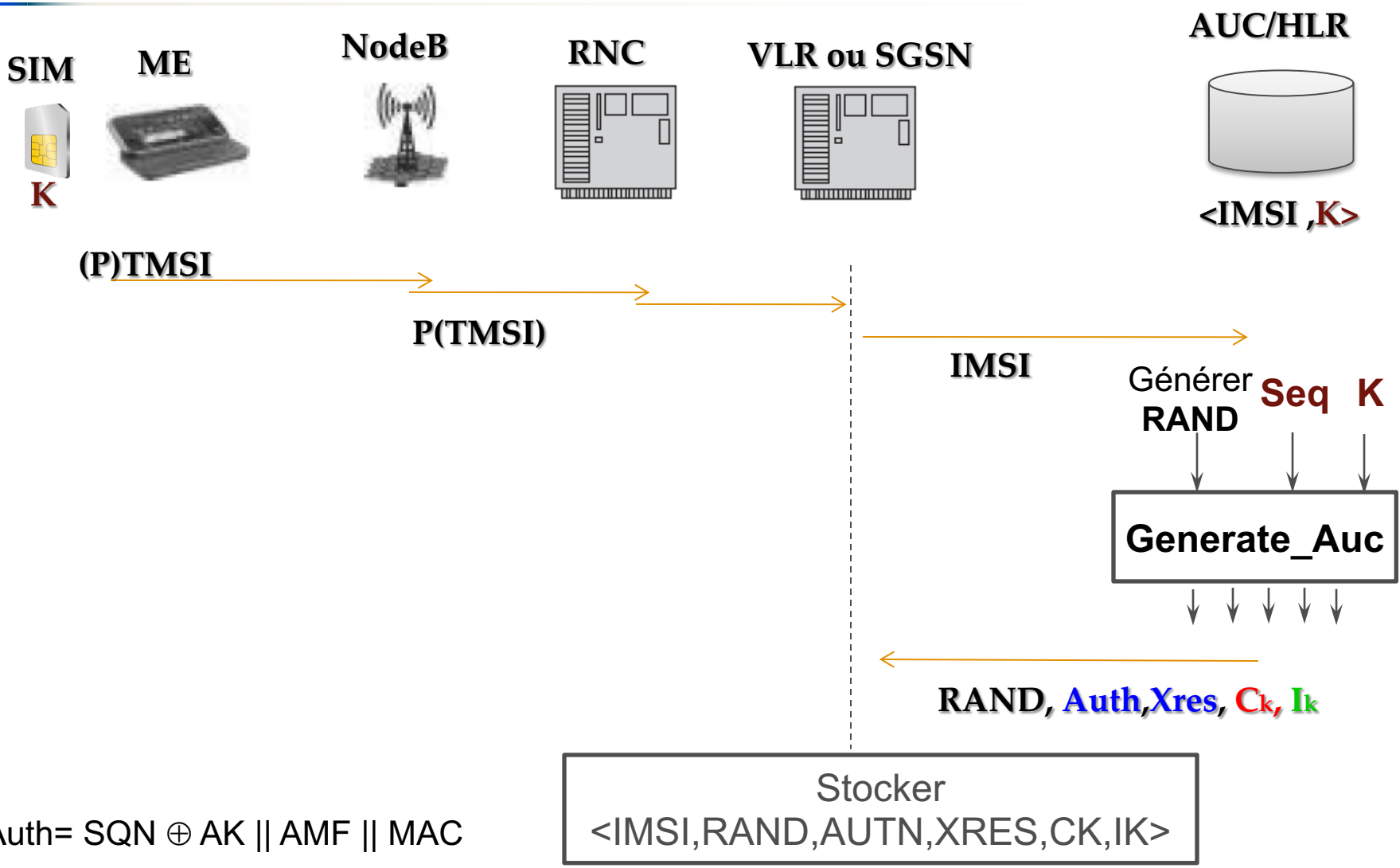
- L'authentification des utilisateurs à la carte USIM grâce à des codes PIN
- Identificateur temporaire :
  - TMSI : Domaine circuit (CS)
  - PTMSI : Domaine paquet (PS)
- Services de sécurité:
  - Authentification
  - Chiffrement
  - Intégrité des messages de contrôle

Sécurité UMTS

- K: clé secrète partagée entre l'AuC et USIM (128 bits)
- USIM et AuC ont un numéro de séquence synchronisé SQN
- RAND nombre aléatoire généré par l'AUC
- AMF: Authentification Management Field (Algo utilisés, durée de vie d'une clé, etc.)

- RES: Réponse au challenge RAND
- MAC: Code d'authentification à envoyer au mobile
- A_k : Clé utilisée pour masquer le numéro de séquence
- C_K : Clé de chiffrement (128 bits)
- I_K: Clé d'intégrité

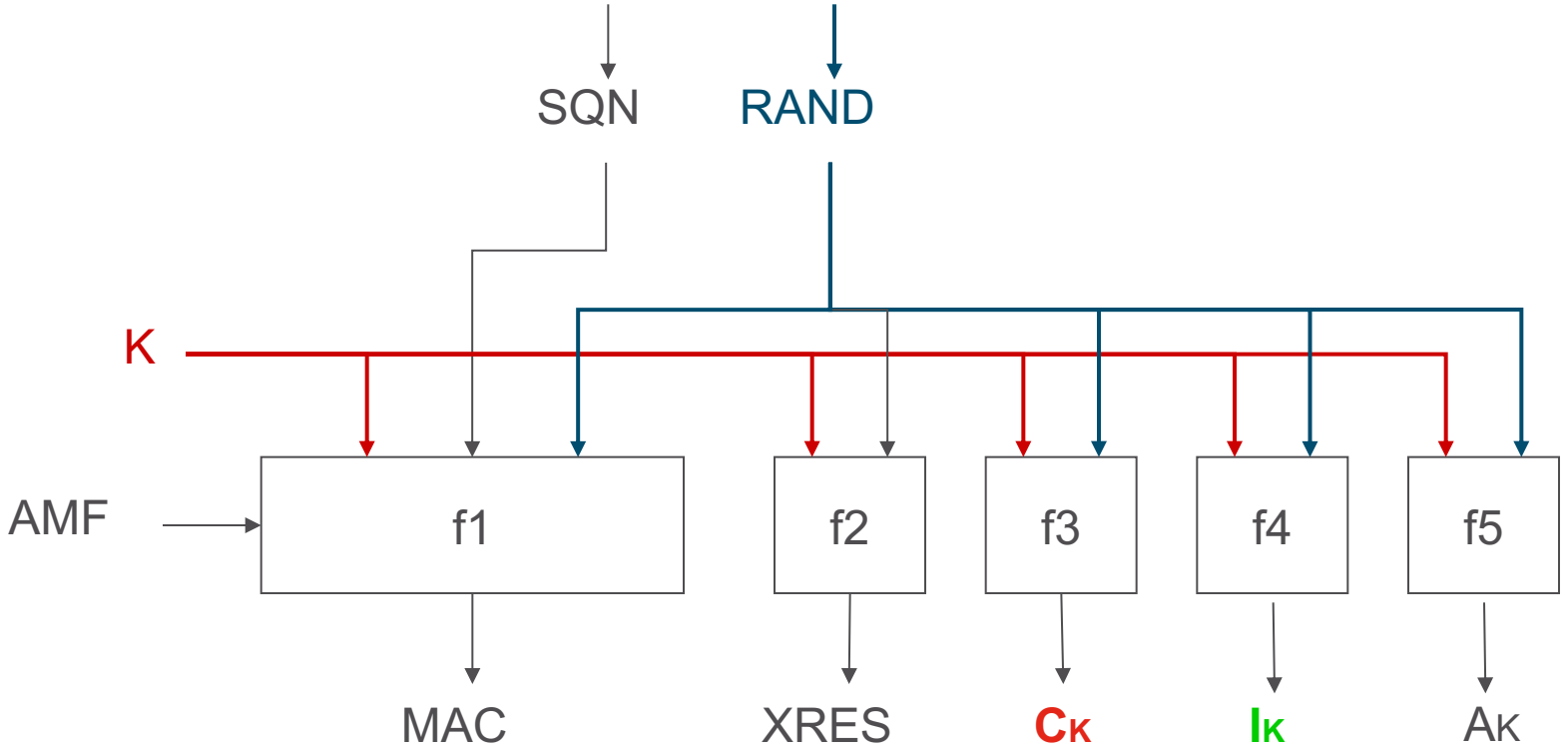
Authentification et génération de clés



*Auth= SQN ⊕ AK || AMF || MAC

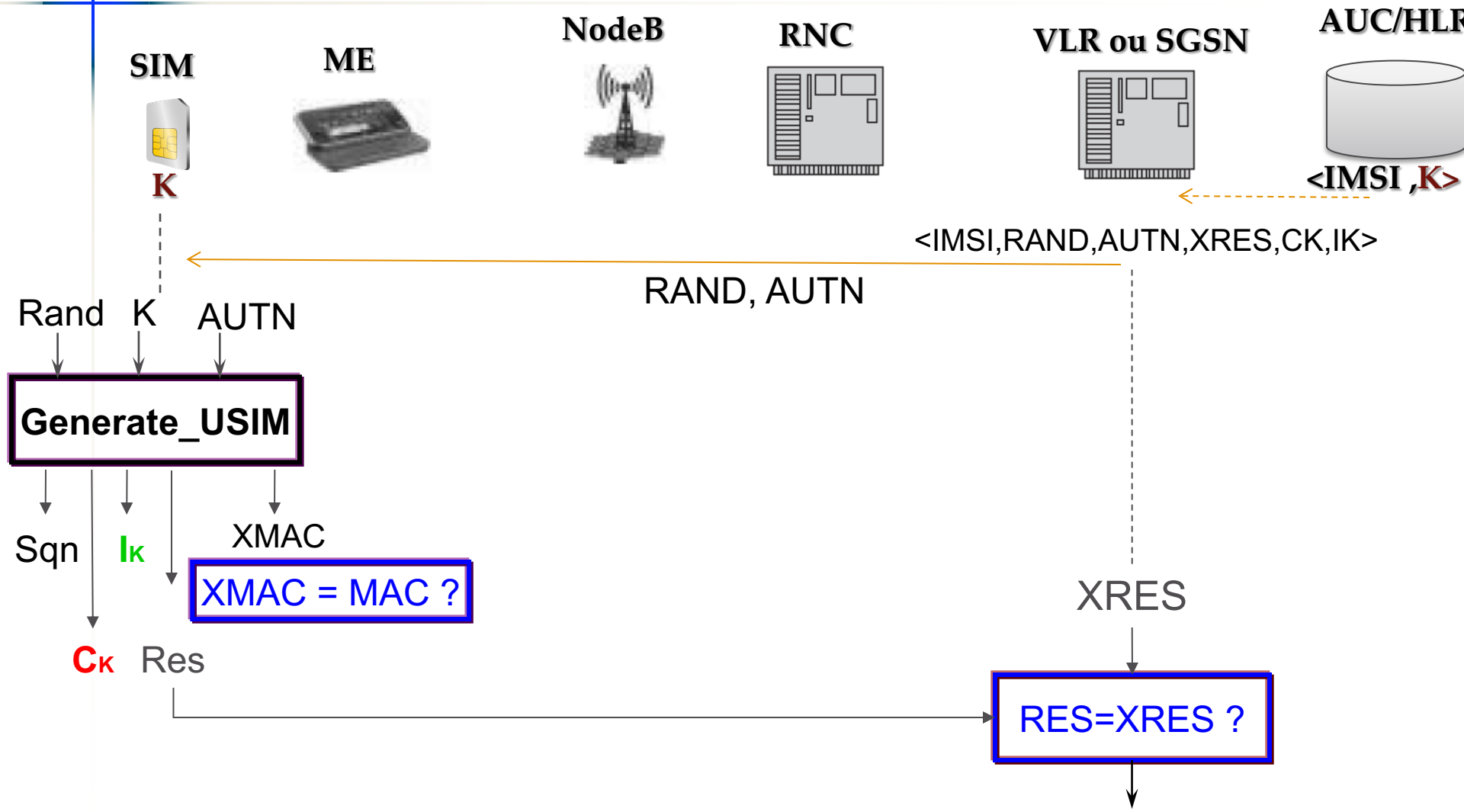
Authentification et génération de clés (Auc)

Détails de la fonction Generate_Auc:



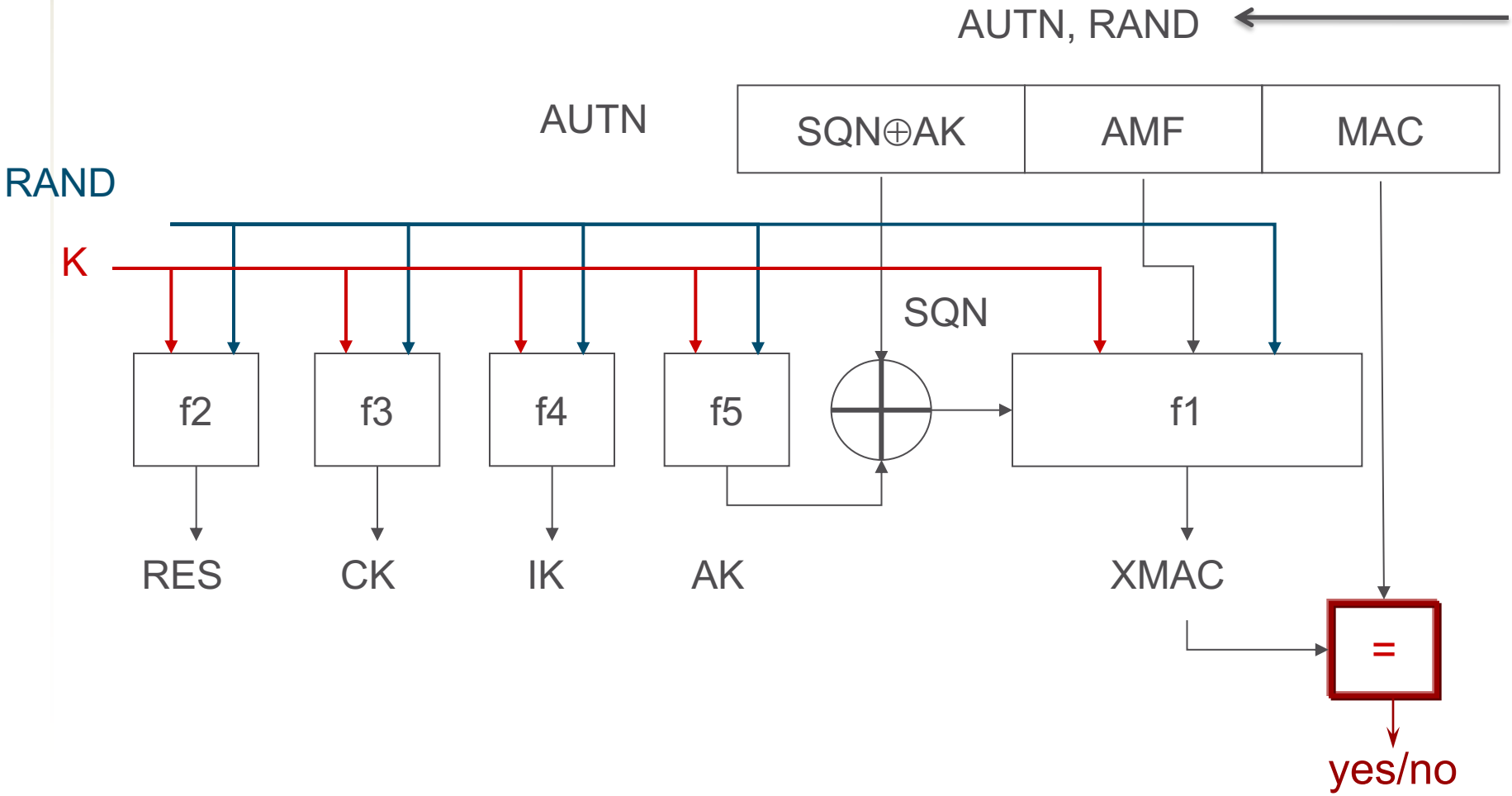
*Autn= SQN ⊕ AK || AMF || MAC

Authentification Mutuelle



Authentification et génération de clés: USIM

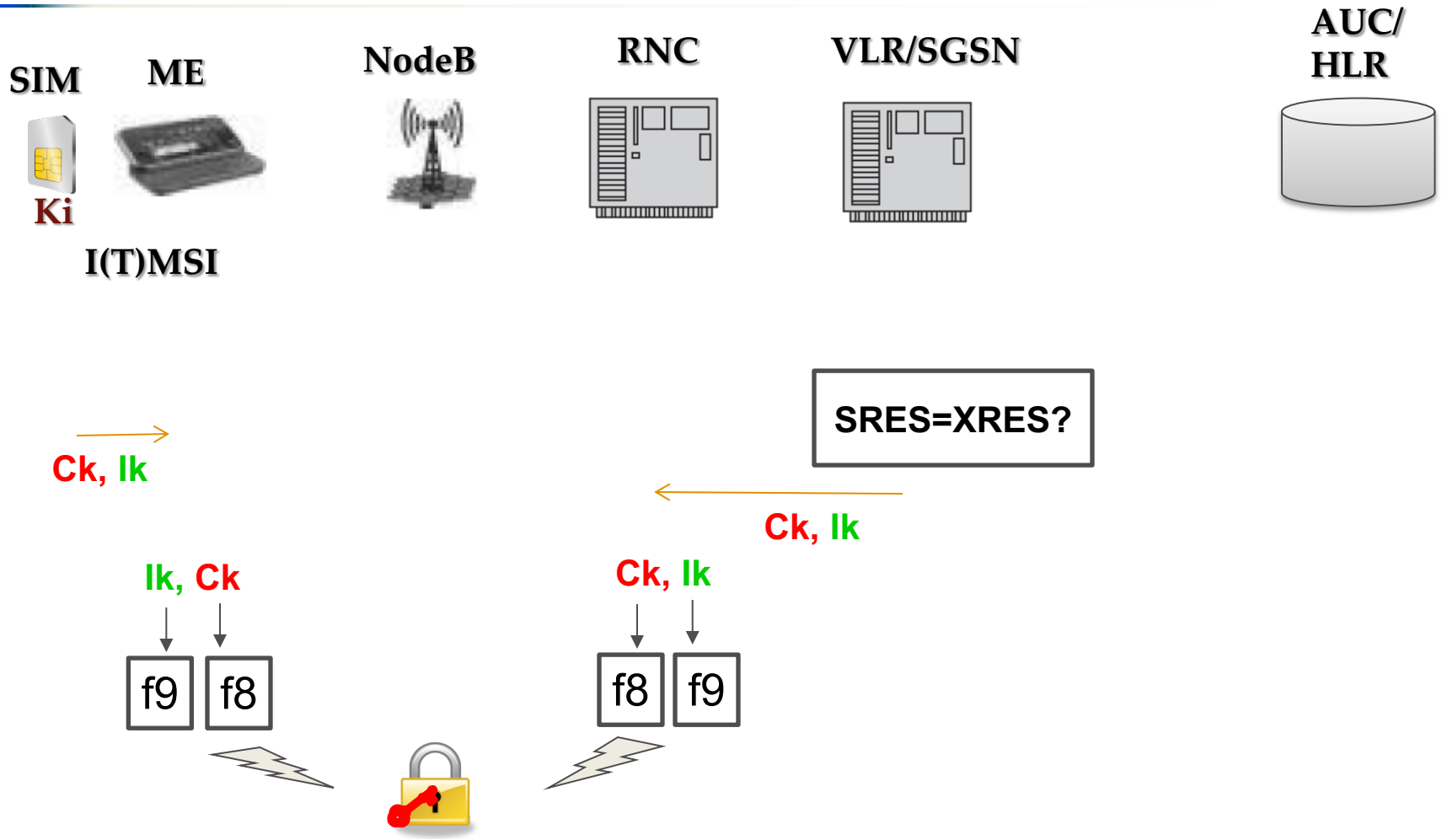
Détails de la fonction Generate_USIM:



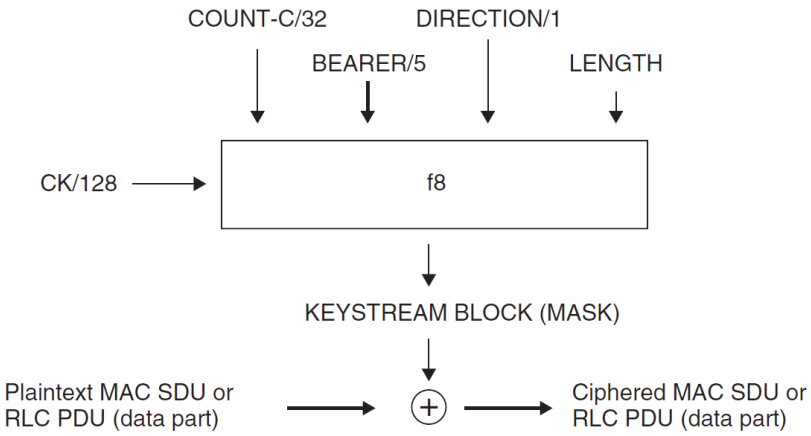
Algorithmes f1 … f5

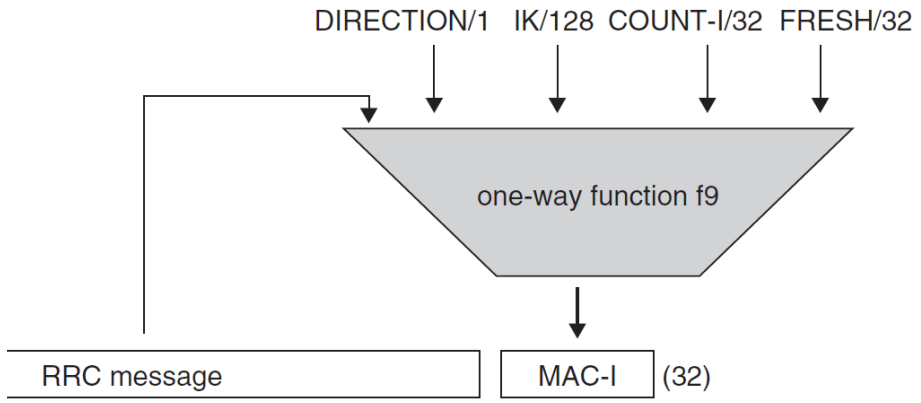
- Implémenté dans l'USIM et l'AuC
- Exécuté dans un espace sûr
- L'implémentation la plus utilisée: MILENAGE (connue aussi sous le nom de Comp128-4)
- Chiffrement par bloc (AES) avec des clés de taille 128 bits

Distribution de la clé de session



Confidentialité et intégrité





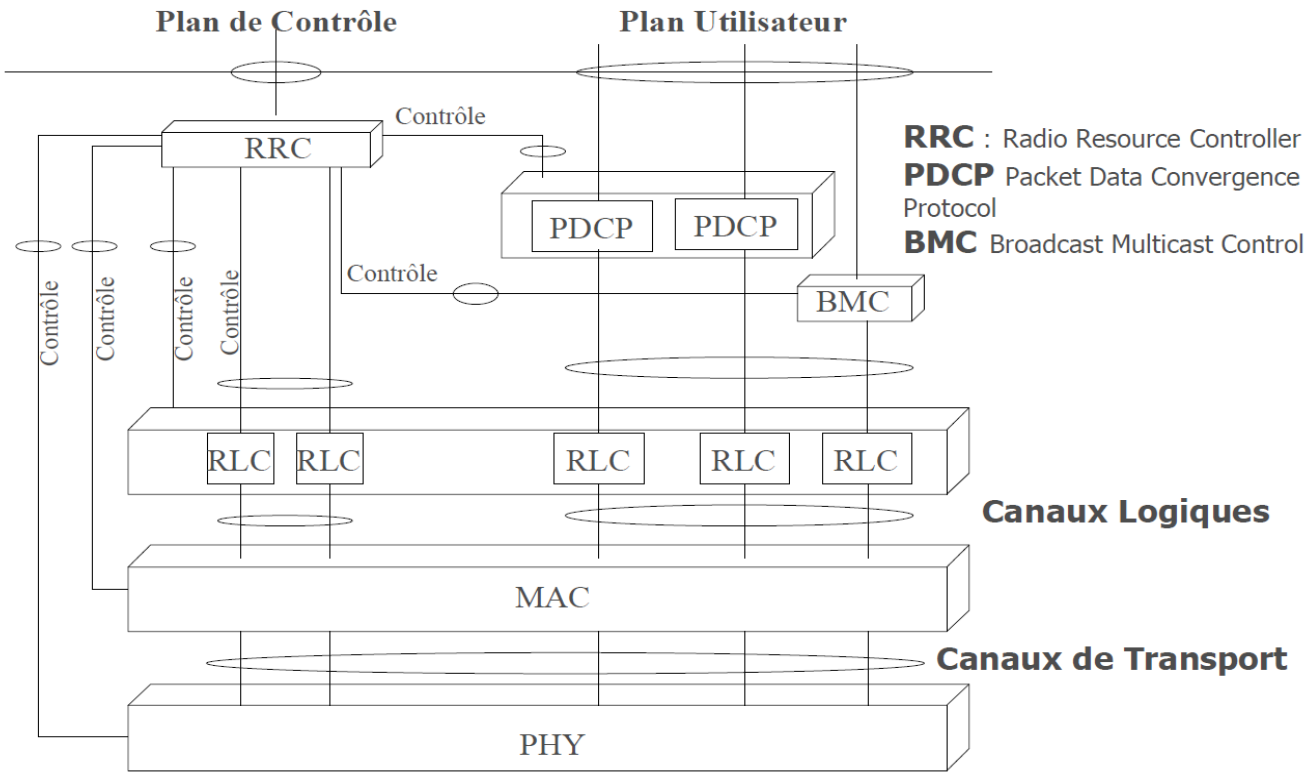
** Dan Forsberg, Günther Horn, Wolf-Dietrich Moeller and Valtteri Niem, LTE Security, John Wiley & Sons, 2011*

- Confidentialité: f8 et Intégrité : f9
- **Implémentations:**

  UEA1 and UIA1 basés sur l'algorithme KASUMI

  UEA2 and UIA2 basés sur l'algorithme SNOW3G

Confidentialité et intégrité



Intégrité au niveau RRC
Chiffrement au niveau RLC (non transparent) ou MAC (transparent)

Pas d'intégrité !
Chiffrement au niveau RLC (non transparent) ou MAC (transparent)

* A. BEYLOT, Architecture Protocolaire de l'UMTS cours UMTS, ENSEEIHT, Toulouse

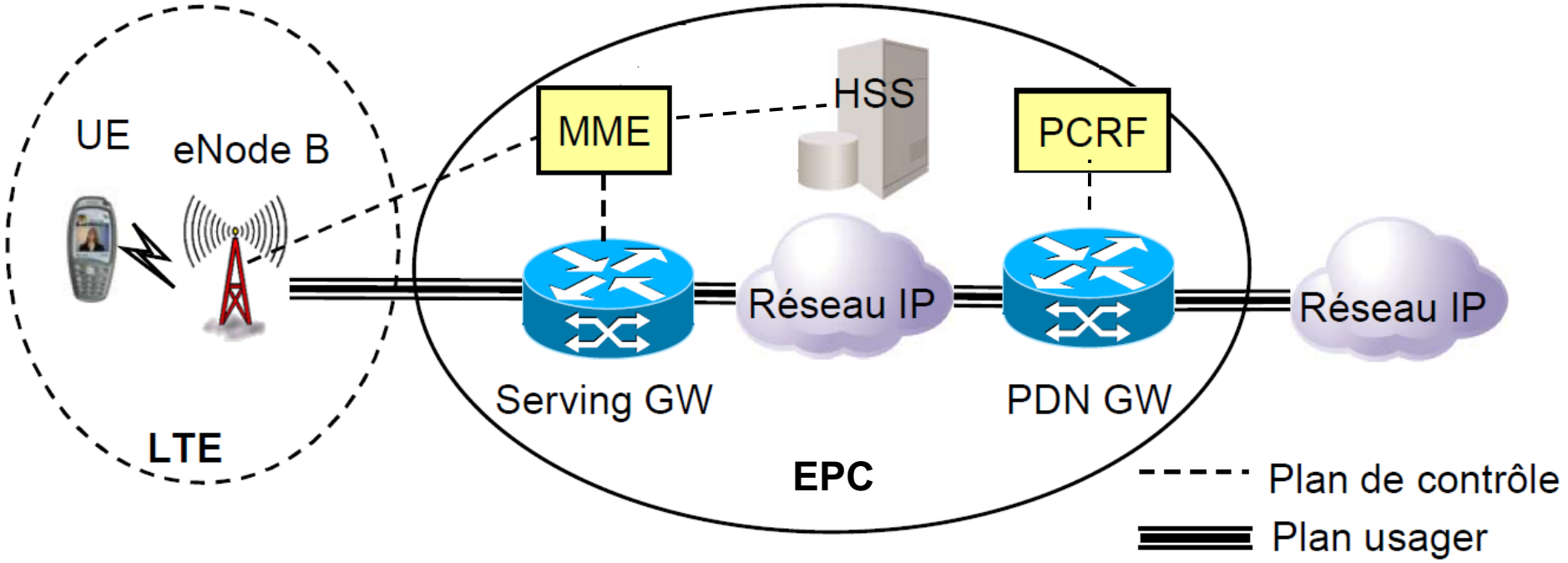
Réseaux de quatrième génération

Réseaux de quatrième génération (EPS)

- Un débit maximal de 100 Mbps en voie descendance et 50 Mbps sur voie montante (pour une largeur de bande de 20 MHz)
- Duplexage temporel (TDD) ou fréquentiel (FDD)
- Utilisation d'antennes MIMO (Multiple Input Multiple Output) et des techniques de transmission OFDM (Orthogonal Frequency Division Multiplexing)

- Simplification de l'architecture physique (détails plus loin)
- Réseau cœur (EPC): tout IP (un seul domaine paquet)
- Séparation entre les plan contrôle et le plan usager

Architecture Physique



* EFORT, LTE + SAE = EPS Principes et Architecture(http://www.efort.com)

Architecture Physique:

- **e-NodeB (Station de base des réseaux LTE)** :

  - Un seul équipement responsable du lien radio avec l'UE (RNC supprimé et ses fonctions réparties entre l'eNodeB et MME/S-GW

- **MME: Gérer les flux du plan de contrôle**

  - Gestion de mobilité (attachement, détachement, mise à jour de localisation), gestion des sessions (établissement/libération des sessions)

  - Authentification des UEs à partir des informations recueillies du HSS/AUC

  - Sélection du S-GW, Sélection de MME (handover avec chang. de MME)

- **HSS (Home Subscriber Server)**

  - Equivalent au HLR et Auc

Architecture Physique: Réseau d'accès

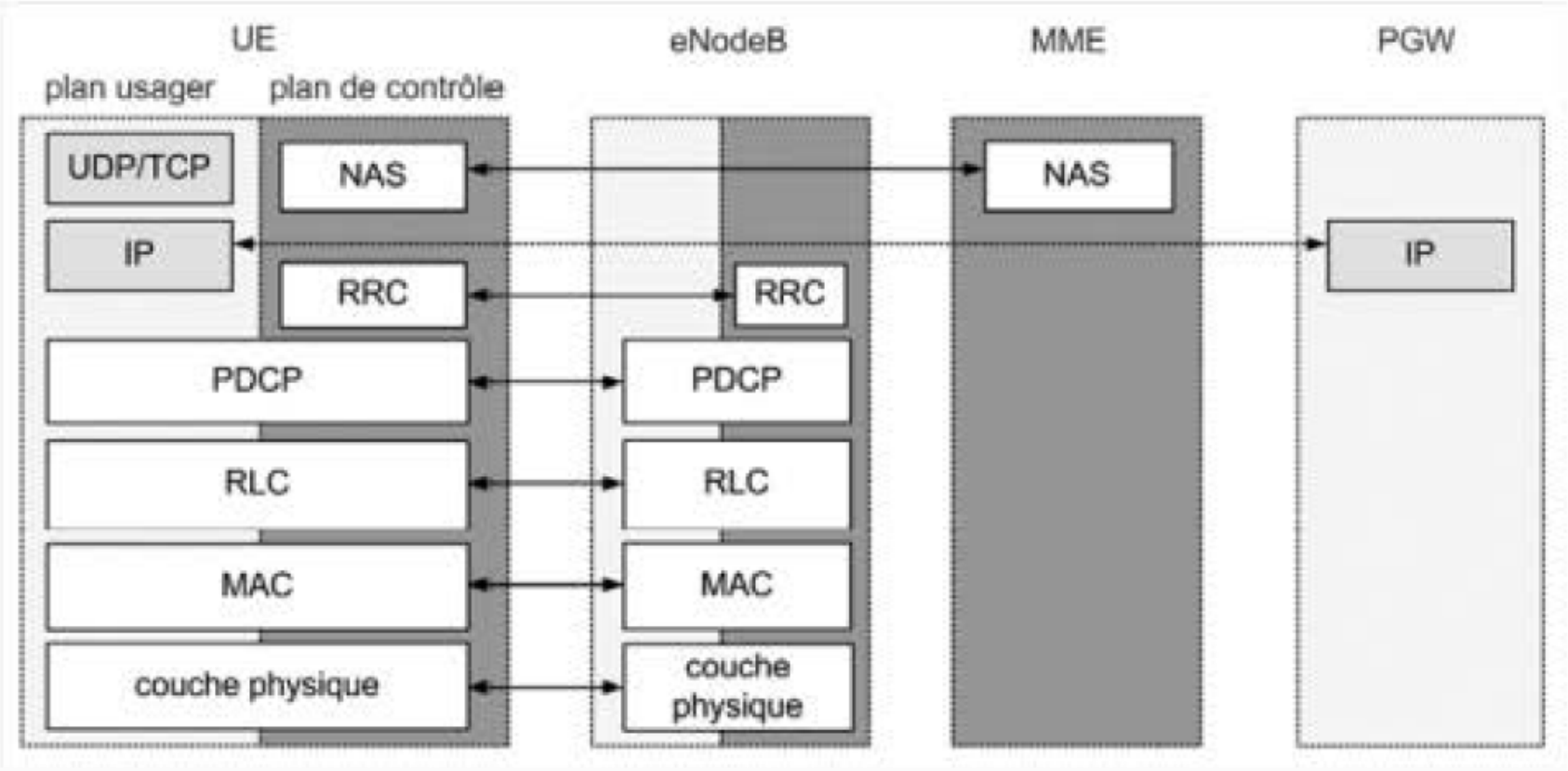
Serving Gateway (S-GW)

- Point d'ancrage pour les pour les sessions de données lorsque l'UE est en mobilité entre plusieurs eNodeB
- Mise en mémoire des paquets entrants (UE destinataire Idle)
- Routage et relai des paquets: router les paquets sortant au PD-GW approprié et relayer les paquets entrants à l'eNodeB servant l'UE

Packet Data Network Gateway (PD-GW):

- Interface vers les réseaux externes
- Allocation de l'adresse IP de l'UE
- Marquage des paquets dans les sens montant et descendant
- Mettre en place une facturation par flux de données (le PCRF applique des règles de gestion évoluées sur le trafic et la facturation de l'utilisateur)

Architecture protocolaire



* Y. Bouguen, É. Hardouin, F. Wolff, LT, E et les reseaux 4G, EYROLLES, 2012,

Sécurité 4G : Axes de sécurité

- **Confidentialité de l'identité de l'abonné:** Id temporaire GUTI généré par le MME lors de l'enregistrement initial (= GUMMEI + M-TMSI)

- **Confidentialité de l'identité du terminal:** IMEI: enregistré de façon sûre et transmis seulement après l'activation de la sécurité

- **Confidentialité des données de l'usager et de la signalisation:**
  - Chiffrement des données de l'usager et de la signalisation RRC sur l'interface radio (entre l'UE et eNodeB)
  - Chiffrement de la signalisation NAS entre l'UE et le MME

- **Intégrité des données de signalisation**
  - Appliquée sur tous les échanges sauf les messages échangés avant l'activation de la sécurité: (Attach Request, Identity Request, RRC Connection Request, RRC Connection Setup, etc.)

- **Pas d'intégrité des données du plan usager**
  - Peut être réalisée par les couches supérieures Ipsec, etc.

Authentification et génération de clés

Très similaire à l'authentification UMTS:

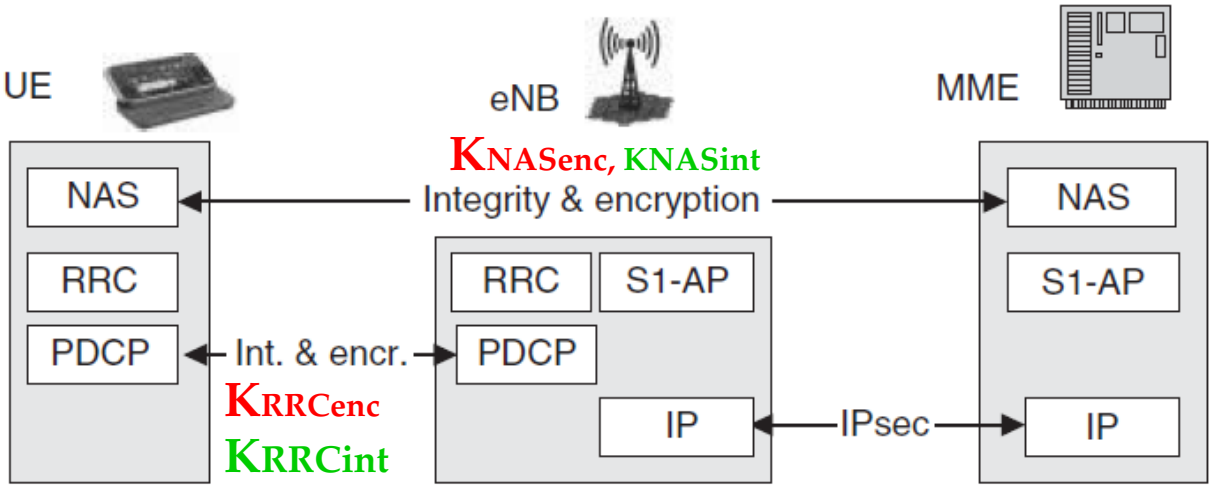
- Clé secrète K (USIM et Auc)
- Authentification mutuelle
- Des clés intermédiaires CK et IK sont calculées par l'AuC et 'USIM

Différences:

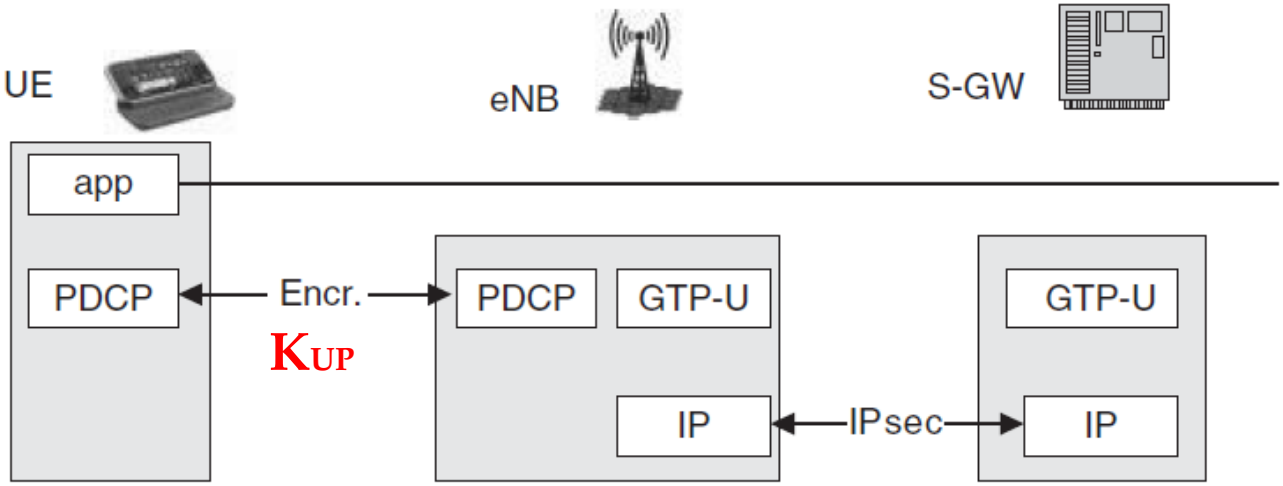
- La hiérarchie des clés: elle est constituée de plusieurs niveaux intermédiaires (CK/ IK, K_ASME et K_eNB (voir slide suivant)
- Chiffrement UE <--> l'eNodeB et UE <--> MME (protection de l'enodeB)
- Nouvelle dérivation des clés lors d'un handover entre deux eNodeB
- Un seul domaine ce qui évite la double authentification
- Nouveaux algorithmes de chiffrement et d'intégrité
- Chiffrement des données au niveau de la couche PDCP

Utilisation des clés

Plan Contrôle

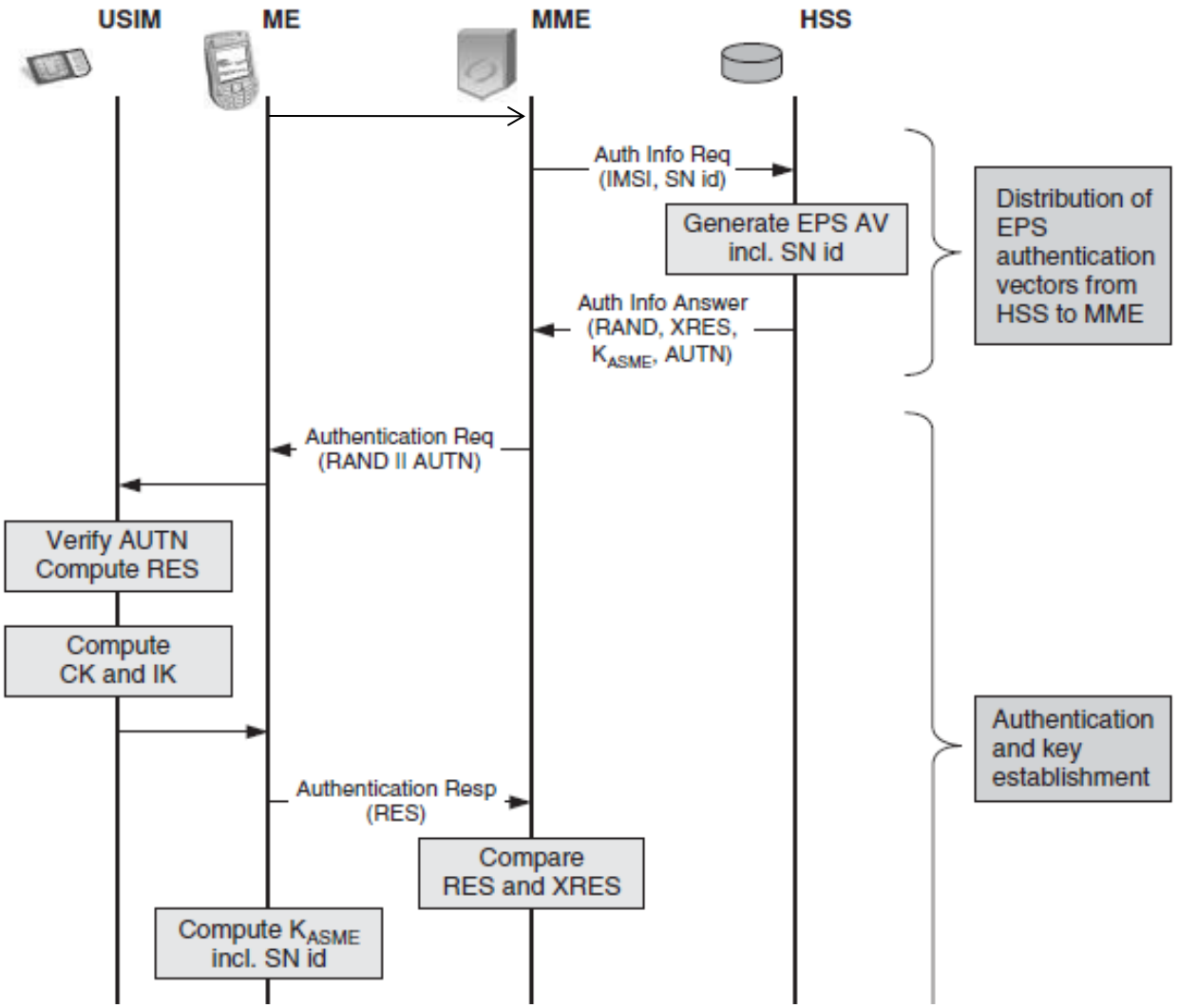


Plan Usager



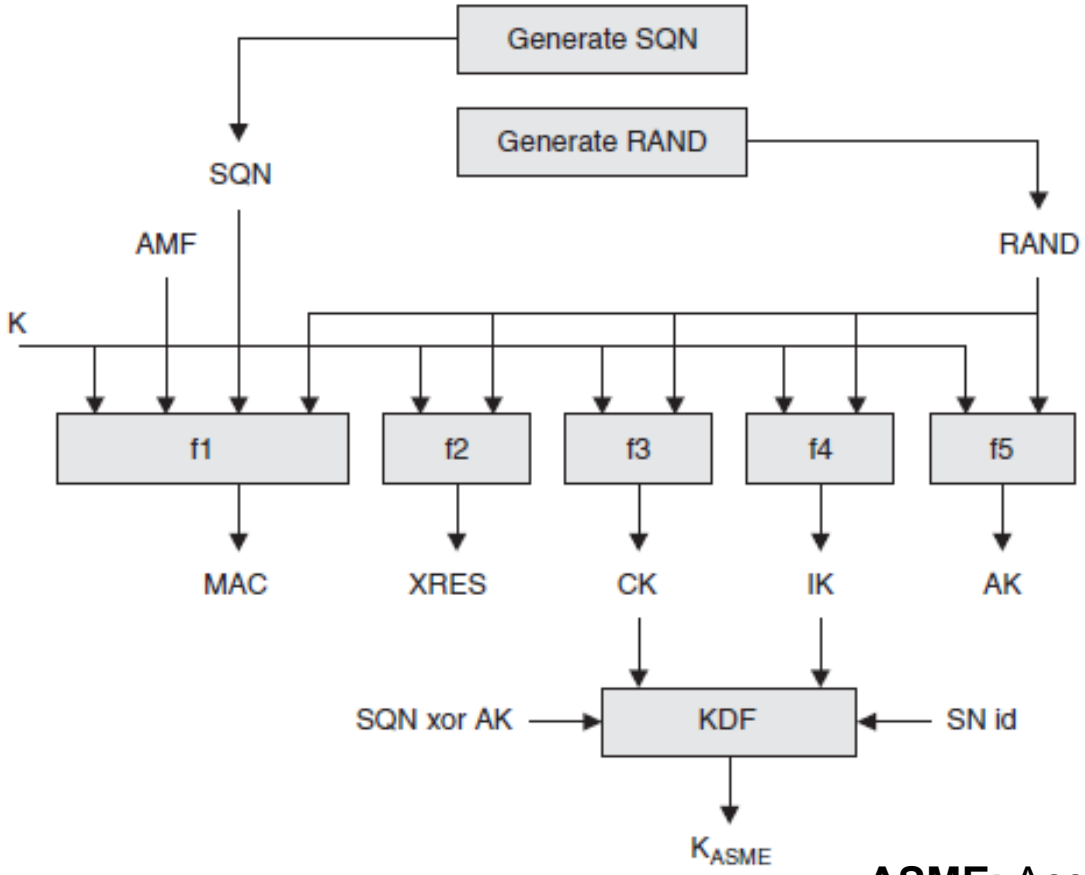
** Adaptée de: D.F., G. Horn, W.Di. Moeller and V. Niem, LTE Security, John Wiley & Sons, 2011*

Authentification et génération de clés



** Adaptée de: D.F., G. Horn, W.Di. Moeller and V. Niem, LTE Security, John Wiley & Sons, 2011*

Authentification et génération de clés (HSS/AUC)



AUTN := SQN xor AK || AMF || MAC

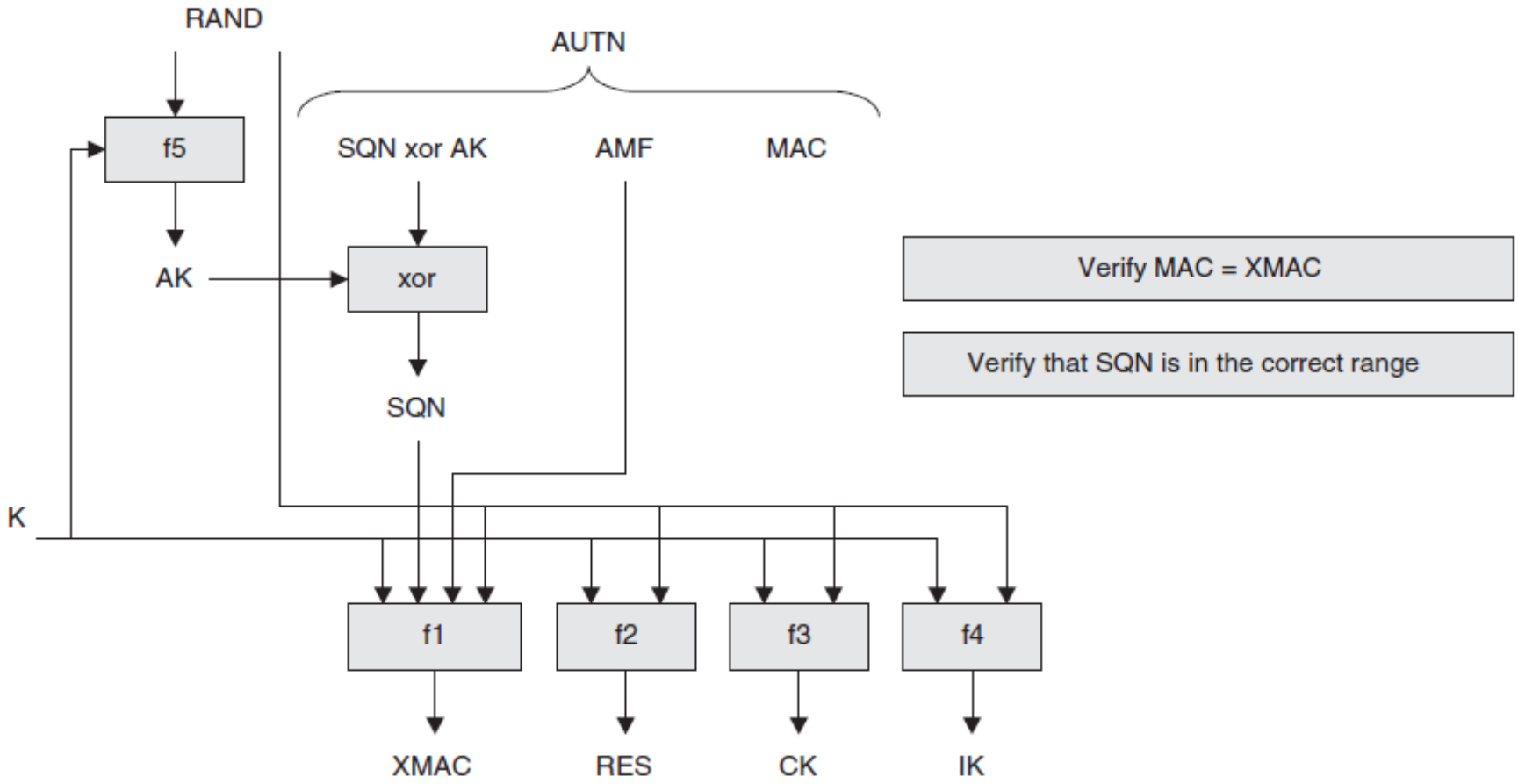
UMTS AV := RAND || XRES || CK || IK || AUTN

EPS AV := RAND || XRES || K_{ASME} || AUTN

ASME: Access Security Management Entity
SN Id: mobile country code and mobile network code

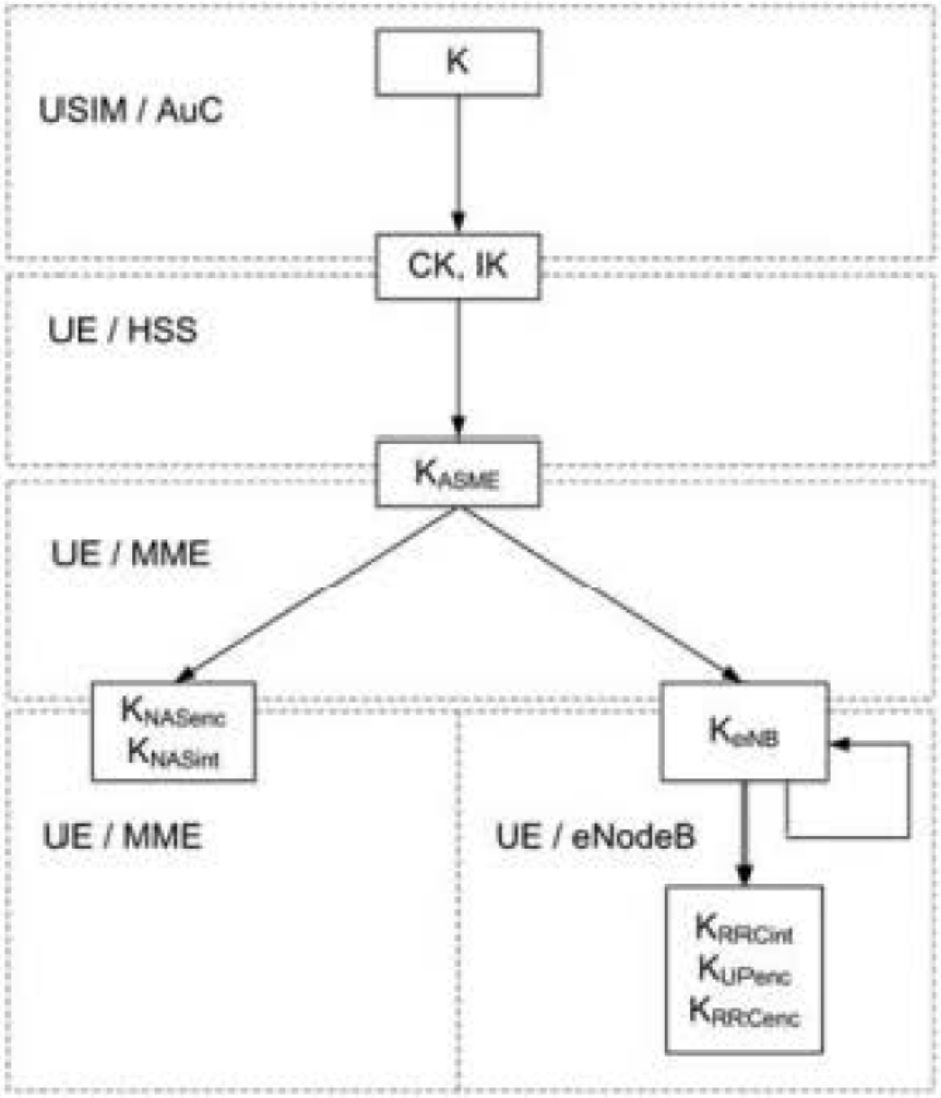
** Dan Forsberg, Günther Horn, Wolf-Dietrich Moeller and Valtteri Niem, LTE Security, John Wiley & Sons, 2011*

Authentification et génération de clés (UE)



** Dan Forsberg, Günther Horn, Wolf-Dietrich Moeller and Valtteri Niem, LTE Security, John Wiley & Sons, 2011*

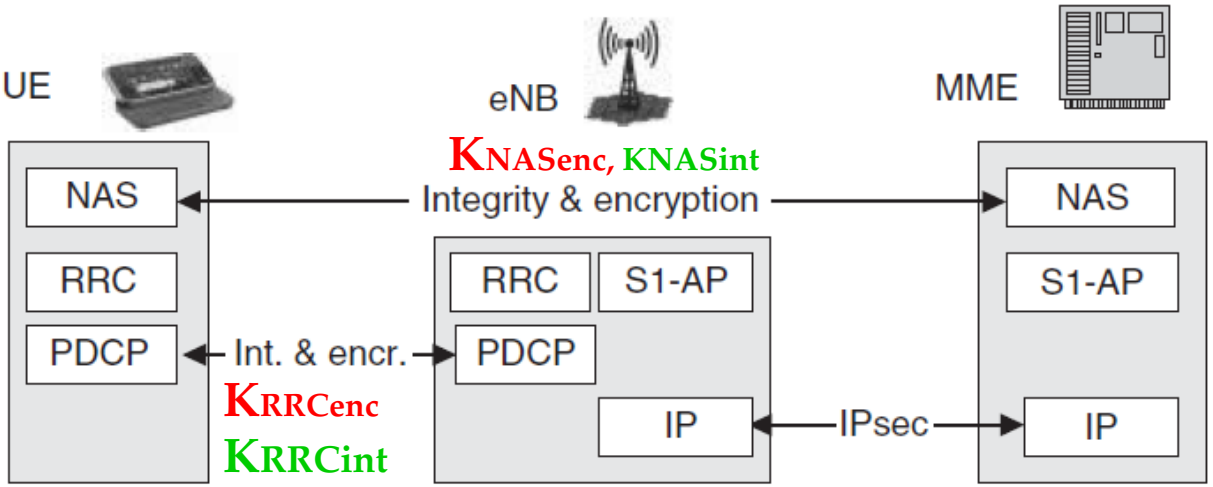
Hiéarchie des clés



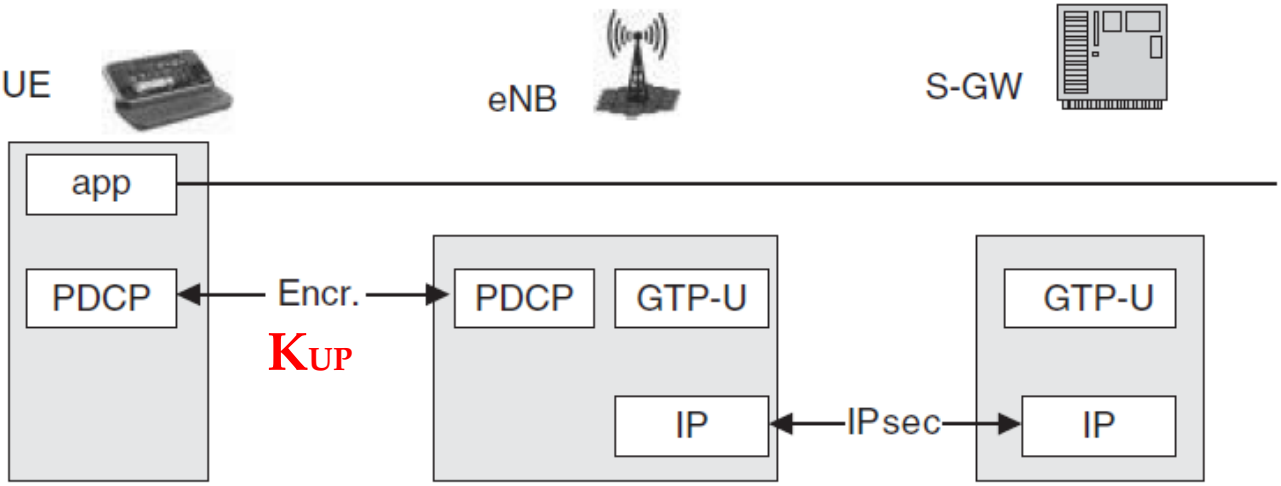
* Y. Bouguen, É. Hardouin, F. Wolff, LTE et les reseaux 4G, EYROLLES, 2012

Utilisation des clés

Plan Contrôle



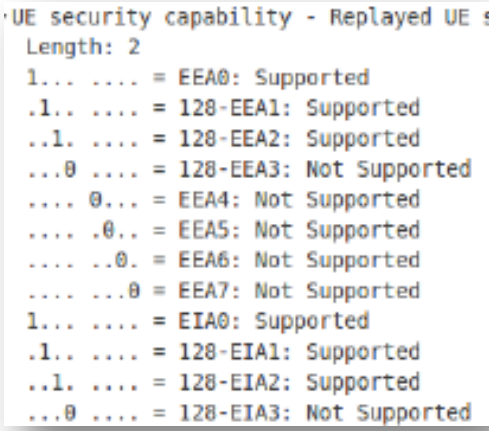
Plan Usager



** Adaptée de: D.F., G. Horn, W.Di. Moeller and V. Niem, LTE Security, John Wiley & Sons, 2011*

Algorithmes de chiffrement et d'intégrité

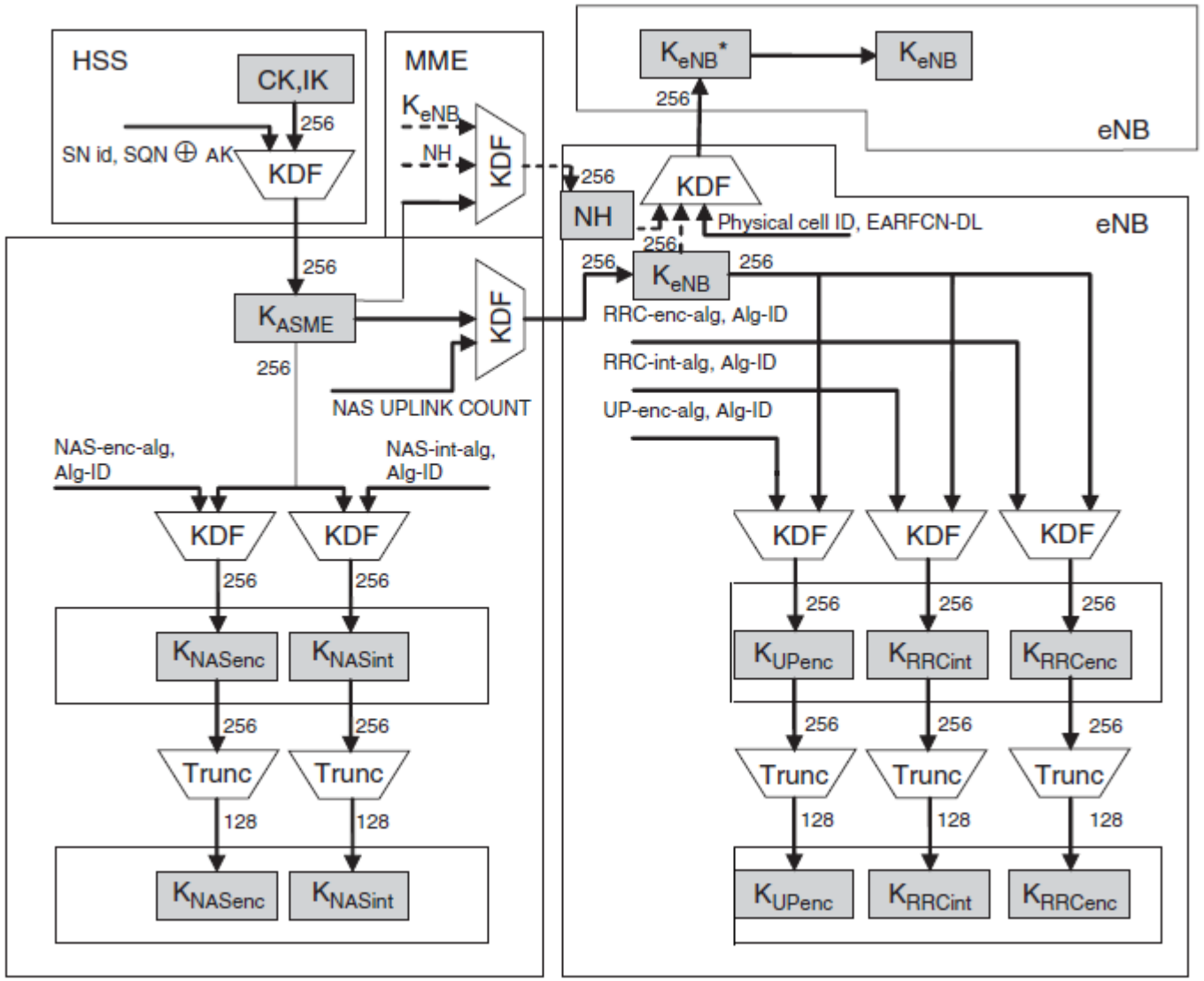
- Similaire aux réseaux UMTS (confidentialité + intégrité)
  - EEA1/EIA1 – basé sur SNOW 3G
  - EEA2/EIA2 – basé sur AES (USA)
  - EEA3/EIA3 – basé sur ZUC (China)



- MME choisit les algorithmes sur la base de ses capacités et de celles de l'UE (Possibilité de choisir des algorithmes différents conf / intég)

- K_{eNb} et K_{asme} sur 256 bits
- Toutes les clés de chiffrement et d'intégrité sont générées sur 256 bits et tronquées sur 128 bits (possibilité de passage à 256 bits)

Algorithmes de chiffrement et d'intégrité

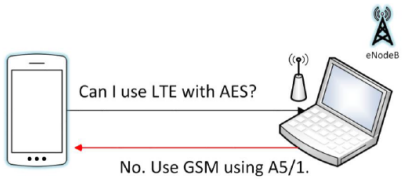


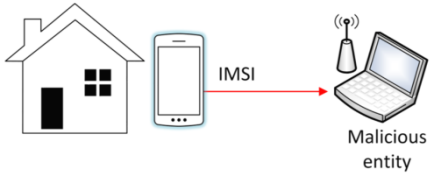
* *Adaptée de: D.F., G. Horn, W.Di. Moeller and V. Niem, LTE Security, John Wiley & Sons, 2011*

Quelques attaques contre les réseaux LTE

- **EnodeB malveillant (Rogue base stations)**
  - **Attaque par renégociation**

    (Solution: Use LTE only' option)

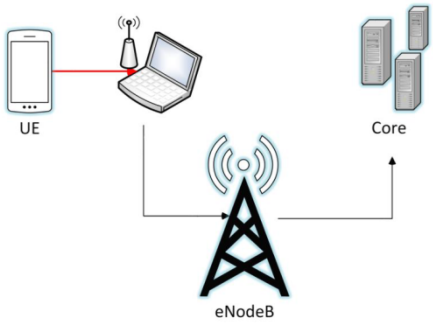




  - **Interception de l'IMEI et de l'IMSI**

  - **Interception des communications**

    (solution: unencrypted connection alert)



Merci !